

CRISC Exam Complete Preparation NEW (Isaca)

CRISC

Certified in Risk and Information Systems Control

**Pass your Exam On the First Try
(Latest Questions & Detailed
Explanation)**

Georgio Daccache

CRISC Exam Complete Preparation NEW (Isaca)

Pass your Exam On the First Try
(Latest Questions & Detailed Explanation)

CRISC is a unique certification that prepares IT professionals for challenges of IT and enterprise risk management, and positions them to become strategic partners to the enterprise.

CRISC certificate holders help enterprises to understand business risk, and have the technical knowledge to implement appropriate IS controls.

In this book contains the latest, Exclusive and most recurrent Practice Questions for CRISC exam so that you can prepare well for this exam.

This book is aligned with ISACA's CRISC Review Manual and covers all the exam topics in order to pass the CRISC exam successfully.

This will help any CRISC candidate to face the CRISC exam with increased confidence.

This book is periodically updated to cover the latest CRISC Review Manual.

If you are a passionate risk practitioner, IT professional, auditor or security professional and are planning to enhance your career by obtaining a CISA certificate easily and save your time and your money, so, this book is for you.

Practice test

1) Which of the following is the MOST important reason to maintain key risk indicators (KRIs)?

- A. In order to avoid risk
- B. Complex metrics require fine-tuning
- C. Risk reports need to be timely
- D. Threats and vulnerabilities change over time

2) You are the project manager of a HGT project that has recently finished the final compilation process.

The project customer has signed off on the project completion and you have to do few administrative closure activities.

In the project, there were several large risks that could have wrecked the project but you and your project team found some new methods to resolve the risks without affecting the project costs or project completion date.

What should you do with the risk responses that you have identified during the project's monitoring and controlling process?

- A. Include the responses in the project management plan.
- B. Include the risk responses in the risk management plan.
- C. Include the risk responses in the organization's lessons learned database.
- D. Nothing. The risk responses are included in the project's risk register already.

3) You are the project manager of GHT project. You have identified a risk event on your project that could save \$100,000 in project costs if it occurs.

Which of the following statements BEST describes this risk event?

- A. This risk event should be mitigated to take advantage of the savings.
- B. This is a risk event that should be accepted because the rewards outweigh the threat to the project.
- C. This risk event should be avoided to take full advantage of the potential savings.
- D. This risk event is an opportunity to the project and should be exploited.

4) You are the project manager of a large construction project.

This project will last for 18 months and will cost \$750,000 to complete.

You are working with your project team, experts, and stakeholders to identify risks within the project before the project work begins.

Management wants to know why you have scheduled so many risk identification meetings throughout the project rather than just initially during the project planning.

What is the best reason for the duplicate risk identification sessions?

- A. The iterative meetings allow all stakeholders to participate in the risk identification processes throughout the project phases.
- B. The iterative meetings allow the project manager to discuss the risk events which have passed the project and which did not happen.
- C. The iterative meetings allow the project manager and the risk identification participants to identify newly discovered risk events throughout the project.
- D. The iterative meetings allow the project manager to communicate pending risks events during project execution.

5) You are the risk official in Bluewell Inc. You are supposed to prioritize several risks. A risk has a rating for occurrence, severity, and detection as 4, 5, and 6, respectively.

What Risk Priority Number (RPN) you would give to it?

- A. 120
- B. 100
- C. 15
- D. 30

6) Which of the following is the MOST important use of KRIs?

- A. Providing a backward-looking view on risk events that have occurred
- B. Providing an early warning signal

- C. Providing an indication of the enterprise's risk appetite and tolerance
- D. Enabling the documentation and analysis of trends

7) Which of the following role carriers will decide the Key Risk Indicator of the enterprise?

Each correct answer represents a part of the solution. Choose two.

- A. Business leaders
- B. Senior management
- C. Human resource
- D. Chief financial officer

8) What are the requirements for creating risk scenarios?

Choose three.

- A. Determination of cause and effect
- B. Determination of the value of business process at risk
- C. Potential threats and vulnerabilities that could cause loss
- D. Determination of the value of an asset

9) You work as the project manager for Bluewell Inc. Your project has several risks that will affect several stakeholder requirements. Which project management plan will define who will be available to share information on the project risks?

- A. Resource Management Plan

- B. Risk Management Plan
- C. Stakeholder management strategy
- D. Communications Management Plan

10) Which of the following controls is an example of non-technical controls?

- A. Access control
- B. Physical security
- C. Intrusion detection system
- D. Encryption

11) You are the project manager of GHT project. Your project team is in the process of identifying project risks on your current project. The team has the option to use all of the following tools and techniques to diagram some of these potential risks EXCEPT for which one?

- A. Process flowchart
- B. Ishikawa diagram
- C. Influence diagram
- D. Decision tree diagram

12) Which of the following BEST describes the utility of a risk?

- A. The finance incentive behind the risk
- B. The potential opportunity of the risk

- C. The mechanics of how a risk works
- D. The usefulness of the risk to individuals or groups

13) Which of the following aspect of monitoring tool ensures that the monitoring tool has the ability to keep up with the growth of an enterprise?

- A. Scalability
- B. Customizability
- C. Sustainability
- D. Impact on performance

14) You are the project manager in your enterprise. You have identified risk that is noticeable failure threatening the success of certain goals of your enterprise.

In which of the following levels do this identified risk exists?

- A. Moderate risk
- B. High risk
- C. Extremely high risk
- D. Low risk

15) Courtney is the project manager for her organization. She is working with the project team to complete the qualitative risk analysis for her

project. During the analysis Courtney encourages the project team to begin the grouping of identified risks by common causes.

What is the primary advantage to group risks by common causes during qualitative risk analysis?

- A. It helps the project team realize the areas of the project most laden with risks.
- B. It assist in developing effective risk responses.
- C. It saves time by collecting the related resources, such as project team members, to analyze the risk events.
- D. It can lead to the creation of risk categories unique to each project.

16) Which of the following processes is described in the statement below?

"It is the process of exchanging information and views about risks among stakeholders, such as groups, individuals, and institutions."

- A. Risk governance
- B. Risk identification
- C. Risk response planning
- D. Risk communication

17) You are an experienced Project Manager that has been entrusted with a project to develop a machine which produces auto components. You have scheduled meetings with the project team and the key stakeholders to identify the risks for your project. Which of the following is a key output of this process?

- A. Risk Register
- B. Risk Management Plan
- C. Risk Breakdown Structure
- D. Risk Categories

18) Which of the following components of risk scenarios has the potential to generate internal or external threat on an enterprise?

- A. Timing dimension
- B. Events
- C. Assets
- D. Actors

19) You are the project manager of GHT project.

You have planned the risk response process and now you are about to implement various controls.

What you should do before relying on any of the controls?

- A. Review performance data
- B. Discover risk exposure
- C. Conduct pilot testing
- D. Articulate risk

20) Which of the following is NOT true for risk management capability maturity level 1?

A. There is an understanding that risk is important and needs to be managed, but it is viewed as a technical issue and the business primarily considers the downside of IT risk

B. Decisions involving risk lack credible information

C. Risk appetite and tolerance are applied only during episodic risk assessments

D. Risk management skills exist on an ad hoc basis, but are not actively developed.

21) An enterprise has identified risk events in a project. While responding to these identified risk events, which among the following stakeholders is MOST important for reviewing risk response options to an IT risk.

A. Information security managers

- B. Internal auditors
- C. Incident response team members
- D. Business managers

22) Which of the following is a technique that provides a systematic description of the combination of unwanted occurrences in a system?

- A. Sensitivity analysis
- B. Scenario analysis
- C. Fault tree analysis
- D. Cause and effect analysis

23) What is the process for selecting and implementing measures to impact risk called?

- A. Risk Treatment
- B. Control
- C. Risk Assessment
- D. Risk Management

24) Which section of the Sarbanes-Oxley Act specifies "Periodic financial reports must be certified by CEO and CFO"?

- A. Section 302
- B. Section 404

C. Section 203

D. Section 409

25) What is the PRIMARY need for effectively assessing controls?

A. Control's alignment with operating environment

B. Control's design effectiveness

C. Control's objective achievement

D. Control's operating effectiveness

26) You work as the project manager for Bluewell Inc. There has been a delay in your project work that is adversely affecting the project schedule. You decide, with your stakeholders' approval, to fast track the project work to get the project done faster. When you fast track the project, what is likely to increase?

A. Human resource needs

B. Quality control concerns

C. Costs

D. Risks

27) David is the project manager of the HRC Project. He has identified a risk in the project, which could cause the delay in the project. David does not want this risk event to happen so he takes few actions to ensure that the risk event will not happen. These extra steps, however, cost the project an additional \$10,000.

What type of risk response has David adopted?

- A. Avoidance
- B. Mitigation
- C. Acceptance
- D. Transfer

28) Which of the following is the MOST important objective of the information system control?

- A. Business objectives are achieved and undesired risk events are detected and corrected
- B. Ensuring effective and efficient operations
- C. Developing business continuity and disaster recovery plans
- D. Safeguarding assets

29) Which of the following is prepared by the business and serves as a starting point for producing the IT Service Continuity Strategy?

- A. Business Continuity Strategy
- B. Index of Disaster-Relevant Information
- C. Disaster Invocation Guideline
- D. Availability/ ITSCM/ Security Testing Schedule

30) For which of the following risk management capability maturity levels do the statement given below is true?

"Real-time monitoring of risk events and control exceptions exist, as does automation of policy management"

- A. Level 3
- B. Level 0
- C. Level 5
- D. Level 2

31) Which of the following is true for Cost Performance Index (CPI)?

- A. If the $CPI > 1$, it indicates better than expected performance of project
- B. $CPI = \text{Earned Value (EV)} * \text{Actual Cost (AC)}$
- C. It is used to measure performance of schedule
- D. If the $CPI = 1$, it indicates poor performance of project.

32) Which of the following do NOT indirect information?

- A. Information about the propriety of cutoff
- B. Reports that show orders that were rejected for credit limitations.
- C. Reports that provide information about any unusual deviations and individual product margins.

D. The lack of any significant differences between perpetual levels and actual levels of goods.

33) Ben works as a project manager for the MJH Project.

In this project, Ben is preparing to identify stakeholders so he can communicate project requirements, status, and risks. Ben has elected to use a salience model as part of his stakeholder identification process.

Which of the following activities best describes a salience model?

A. Describing classes of stakeholders based on their power (ability to impose their will), urgency (need for immediate attention), and legitimacy (their involvement is appropriate).

B. Grouping the stakeholders based on their level of authority ("power") and their level of concern ("interest") regarding the project outcomes.

C. Influence/impact grid, grouping the stakeholders based on their active involvement ("influence") in the project and their ability to affect changes to the project's planning or execution ("impact").

D. Grouping the stakeholders based on their level of authority ("power") and their active involvement ("influence") in the project.

34) Which of the following is the first MOST step in the risk assessment process?

- A. Identification of assets
- B. Identification of threats
- C. Identification of threat sources
- D. Identification of vulnerabilities

35) Which of the following matrices is used to specify risk thresholds?

- A. Risk indicator matrix
- B. Impact matrix
- C. Risk scenario matrix
- D. Probability matrix

36) What are the two MAJOR factors to be considered while deciding risk appetite level? Each correct answer represents a part of the solution. Choose two.

- A. The amount of loss the enterprise wants to accept
- B. Alignment with risk-culture
- C. Risk-aware decisions
- D. The capacity of the enterprise's objective to absorb loss.

37) You are the project manager of the GHY Project for your company. You need to complete a project management process that will be on the lookout for new risks, changing risks, and risks that are now outdated. Which project management process is responsible for these actions?

- A. Risk planning
- B. Risk monitoring and controlling
- C. Risk identification
- D. Risk analysis

38) You are the project manager of the HGT project in Bluewell Inc. The project has an asset valued at \$125,000 and is subjected to an exposure factor of 25 percent.

What will be the Single Loss Expectancy of this project?

- A. \$ 125,025
- B. \$ 31,250
- C. \$ 5,000
- D. \$ 3,125,000

39) Which of the following are the principles of access controls?

Choose three.

- A. Confidentiality
- B. Availability
- C. Reliability
- D. Integrity

40) You are the project manager of GHT project. You have selected

appropriate Key Risk Indicators for your project. Now, you need to maintain those Key Risk Indicators. What is the MOST important reason to maintain Key Risk Indicators?

- A. Risk reports need to be timely
- B. Complex metrics require fine-tuning
- C. Threats and vulnerabilities change over time
- D. They help to avoid risk

41) Which of the following controls do NOT come under technical class of control?

- A. Program management control
- B. System and Communications Protection control
- C. Identification and Authentication control
- D. Access Control

42) Mary is a project manager in her organization. On her current project she is working with her project team and other key stakeholders to identify the risks within the project. She is currently aiming to create a comprehensive list of project risks so she is using a facilitator to help generate ideas about project risks.

What risk identification method is Mary likely using?

- A. Delphi Techniques
- B. Expert judgment
- C. Brainstorming

D. Checklist analysis

43) Which of the following is an administrative control?

- A. Water detection
- B. Reasonableness check
- C. Data loss prevention program
- D. Session timeout

44) You are the project manager of the NHH Project. You are working with the project team to create a plan to document the procedures to manage risks throughout the project. This document will define how risks will be identified and quantified. It will also define how contingency plans will be implemented by the project team.

What document do you and your team is creating in this scenario?

- A. Project plan
- B. Resource management plan
- C. Project management plan
- D. Risk management plan

45) Where are all risks and risk responses documented as the project progresses?

- A. Risk management plan
- B. Project management plan
- C. Risk response plan
- D. Risk register

46) A part of a project deals with the hardware work. As a project manager, you have decided to hire a company to deal with all hardware work on the project. Which type of risk response is this?

- A. Transference
- B. Mitigation
- C. Avoidance
- D. Exploit

47) John works as a project manager for BlueWell Inc. He is determining which risks can affect the project. Which of the following inputs of the identify risks process is useful in identifying risks associated to the time allowances for the activities or projects as a whole, with a width of the range indicating the degrees of risk?

- A. Activity duration estimates
- B. Activity cost estimates
- C. Risk management plan

D. Schedule management plan

48) Which of the following events refer to loss of integrity?

Each correct answer represents a complete solution. Choose three.

- A. Someone sees company's secret formula
- B. Someone makes unauthorized changes to a Web site
- C. An e-mail message is modified in transit
- D. A virus infects a file

49) Which of the following should be PRIMARILY considered while designing information systems controls?

- A. The IT strategic plan
- B. The existing IT environment
- C. The organizational strategic plan
- D. The present IT budget

50) Which of the following is the MOST effective inhibitor of relevant and efficient communication?

- A. A false sense of confidence at the top on the degree of actual exposure related to IT and lack of a well-understood direction for risk management from the top down
- B. The perception that the enterprise is trying to cover up known risk from stakeholders
- C. Existence of a blame culture
- D. Misalignment between real risk appetite and translation into policies.

51) You and your project team are identifying the risks that may exist within your project. Some of the risks are small risks that won't affect your project much if they happen.

What should you do with these identified risk events?

- A. These risks can be dismissed.
- B. These risks can be accepted.

- C. These risks can be added to a low priority risk watch list.
- D. All risks must have a valid, documented risk response.

52) You are the project manager of your enterprise. You have introduced an intrusion detection system for the control. You have identified a warning of violation of security policies of your enterprise.

What type of control is an intrusion detection system (IDS)?

- A. Detective
- B. Corrective
- C. Preventative
- D. Recovery

53) What are the functions of audit and accountability control?

Each correct answer represents a complete solution. (Choose three.)

- A. Provides details on how to protect the audit logs
- B. Implement effective access control
- C. Implement an effective audit program
- D. Provides details on how to determine what to audit.

54) Which among the following acts as a trigger for risk response process?

- A. Risk level increases above risk appetite
- B. Risk level increase above risk tolerance
- C. Risk level equates risk appetite
- D. Risk level equates the risk tolerance

55) What is the value of exposure factor if the asset is lost completely?

- A. 1
- B. Infinity
- C. 10
- D. 0

56) Your project is an agricultural-based project that deals with plant irrigation systems. You have discovered a byproduct in your project that your organization could use to make a profit. If your organization seizes this opportunity, it would be an example of what risk response?

- A. Enhancing
- B. Positive
- C. Opportunistic
- D. Exploiting

57) Which of the following is true for Single loss expectancy (SLE), Annual rate of occurrence (ARO), and Annual loss expectancy (ALE)?

- A. $ALE = ARO/SLE$
- B. $ARO = SLE/ALE$
- C. $ARO = ALE * SLE$
- D. $ALE = ARO * SLE$

58) Which of the following statements are true for enterprise's risk management capability maturity level 3?

- A. Workflow tools are used to accelerate risk issues and track decisions
- B. The business knows how IT fits in the enterprise risk universe and the risk portfolio view
- C. The enterprise formally requires continuous improvement of risk management skills, based on clearly defined personal and enterprise goals
- D. Risk management is viewed as a business issue, and both the drawbacks and benefits of risk are recognized.

59) Which of the following role carriers is accounted for analyzing risks, maintaining risk profile, and risk-aware decisions?

- A. Business management
- B. Business process owner
- C. Chief information officer (CIO)
- D. Chief risk officer (CRO)

60) You are using Information system. You have chosen a poor password and also sometimes transmits data over unprotected communication lines.

What is this poor quality of password and unsafe transmission referring to?

- A. Probabilities
- B. Threats
- C. Vulnerabilities
- D. Impacts

61) Which of the following is the BEST way to ensure that outsourced service providers comply with the enterprise's information security policy?

- A. Penetration testing
- B. Service level monitoring
- C. Security awareness training
- D. Periodic audits

62) You are the project manager of RFT project. You have identified a risk that the enterprise's IT system and application landscape is so complex that, within a few years, extending capacity will become difficult and maintaining software will become very expensive. To overcome this risk, the response adopted is re- architecture of the existing system and purchase of new integrated system. In which of the following risk prioritization options would this case be categorized?

- A. Deferrals

- B. Quick win
- C. Business case to be made
- D. Contagious risk

63) Which of the following BEST ensures that a firewall is configured in compliance with an enterprise's security policy?

- A. Interview the firewall administrator.
- B. Review the actual procedures.
- C. Review the device's log file for recent attacks.
- D. Review the parameter settings.

64) Which of following is NOT used for measurement of Critical Success Factors of the project?

- A. Productivity
- B. Quality
- C. Quantity
- D. Customer service

65) Which of the following statements is NOT true regarding the risk management plan?

- A. The risk management plan is an output of the Plan Risk Management

process.

B. The risk management plan is an input to all the remaining risk-planning processes.

C. The risk management plan includes a description of the risk responses and triggers.

D. The risk management plan includes thresholds, scoring and interpretation methods, responsible parties, and budgets.

66) You are the project manager of a project in Bluewell Inc.

You and your project team have identified several project risks, completed risk analysis, and are planning to apply most appropriate risk responses.

Which of the following tools would you use to choose the appropriate risk response?

A. Project network diagrams

B. Cause-and-effect analysis

C. Decision tree analysis

D. Delphi Technique

67) You are the risk official of your enterprise. Your enterprise takes important decisions without considering risk credential information and is also unaware of external requirements for risk management and integration with enterprise risk management.

In which of the following risk management capability maturity levels does your enterprise exists?

- A. Level 1
- B. Level 0
- C. Level 5
- D. Level 4

68) Which of the following is the priority of data owners when establishing risk mitigation method?

- A. User entitlement changes
- B. Platform security
- C. Intrusion detection
- D. Antivirus controls

69) What type of policy would an organization use to forbid its employees from using organizational e-mail for personal use?

- A. Anti-harassment policy
- B. Acceptable use policy
- C. Intellectual property policy
- D. Privacy policy

70) Wendy has identified a risk event in her project that has an impact of \$75,000 and a 60 percent chance of happening. Through research, her project team learns that the risk impact can actually be reduced to just \$15,000 with only a ten percent chance of occurring. The proposed solution will cost \$25,000. Wendy agrees to the \$25,000 solution.

What type of risk response is this?

- A. Mitigation

- B. Avoidance
- C. Transference
- D. Enhancing

71) Which of the following processes addresses the risks by their priorities, schedules the project management plan as required, and inserts resources and activities into the budget?

- A. Monitor and Control Risk
- B. Plan risk response
- C. Identify Risks
- D. Qualitative Risk Analysis

72) Out of several risk responses, which of the following risk responses is used for negative risk events?

- A. Share
- B. Enhance

- C. Exploit
- D. Accept

73) Which of the following risks refer to probability that an actual return on an investment will be lower than the investor's expectations?

- A. Integrity risk
- B. Project ownership risk
- C. Relevance risk
- D. Expense risk

74) What are the PRIMARY requirements for developing risk scenarios?

Each correct answer represents a part of the solution. Choose two.

- A. Potential threats and vulnerabilities that could lead to loss events
- B. Determination of the value of an asset at risk
- C. Determination of actors that has potential to generate risk
- D. Determination of threat type

75) What are the responsibilities of the CRO?

Each correct answer represents a complete solution. Choose three.

- A. Managing the risk assessment process
- B. Implement corrective actions
- C. Advising Board of Directors
- D. Managing the supporting risk management function

76) You are working with a vendor on your project. A stakeholder has requested a change for the project, which will add value to the project deliverables. The vendor that you're working with on the project will be affected by the change. What system can help you introduce and execute the stakeholder change request with the vendor?

- A. Contract change control system
- B. Scope change control system
- C. Cost change control system
- D. Schedule change control system

77) You are the project manager of GHT project. You are performing cost and benefit analysis of control. You come across the result that costs of specific controls exceed the benefits of mitigating a given risk.

What is the BEST action would you choose in this scenario?

- A. The enterprise may apply the appropriate control anyway.
- B. The enterprise should adopt corrective control.
- C. The enterprise may choose to accept the risk rather than incur the cost of mitigation.
- D. The enterprise should exploit the risk.

78) Mortality tables are based on what mathematical activity?

Each correct answer represents a complete solution. Choose three.

- A. Normal distributions
- B. Probabilities
- C. Impact
- D. Sampling

79) Harry is the project manager of HDW project. He has identified a risk that could injure project team members. He does not want to accept any risk where someone could become injured on this project so he hires a professional vendor to complete this portion of the project work. What type of risk response is Harry implementing?

- A. Transference
- B. Mitigation
- C. Acceptance
- D. Avoidance

80) The Identify Risk process determines the risks that affect the project and document their characteristics.

Why should the project team members be involved in the Identify Risk process?

- A. They are the individuals that will most likely cause and respond to the risk events.
- B. They are the individuals that will have the best responses for identified risks events within the project.
- C. They are the individuals that are most affected by the risk events.

D. They are the individuals that will need a sense of ownership and responsibility for the risk events.

81) What are the requirements of monitoring risk?

Each correct answer represents a part of the solution. Choose three.

- A. Information of various stakeholders
- B. Preparation of detailed monitoring plan
- C. Identifying the risk to be monitored
- D. Defining the project's scope

82) Your company is covered under a liability insurance policy, which provides various liability coverage for information security risks, including any physical damage of assets, hacking attacks, etc. Which of the following risk management techniques is your company using?

- A. Risk transfer
- B. Risk acceptance
- C. Risk avoidance
- D. Risk mitigation

83) You work as a project manager for BlueWell Inc. Management has asked you to work with the key project stakeholder to analyze the risk events you have identified in the project. They would like you to analyze the project risks with a goal of improving the project's performance as a whole.

What approach can you use to achieve this goal of improving the project's performance through risk analysis with your project stakeholders?

- A. Involve subject matter experts in the risk analysis activities
- B. Involve the stakeholders for risk identification only in the phases where the project directly affects them
- C. Use qualitative risk analysis to quickly assess the probability and impact of risk events
- D. Focus on the high-priority risks through qualitative risk analysis

84) You are a project manager for your organization and you're working with four of your key stakeholders. One of the stakeholders is confused as to why you're not discussing the current problem in the project during the risk identification meeting.

Which one of the following statements best addresses when a project risk actually happens?

- A. Project risks are uncertain as to when they will happen.
- B. Risks can happen at any time in the project.
- C. Project risks are always in the future.
- D. Risk triggers are warning signs of when the risks will happen.

85) Which of the following is the MOST effective method for indicating that the risk level is approaching a high or unacceptable level of risk?

- A. Risk register
- B. Cause and effect diagram
- C. Risk indicator
- D. Return on investment

86) You work as the project manager for Bluewell Inc. Your project has several risks that will affect several stakeholder requirements.

Which project management plan will define who will be available to share information on the project risks?

- A. Risk Management Plan
- B. Stakeholder management strategy
- C. Communications Management Plan
- D. Resource Management Plan

87) Your project spans the entire organization. You would like to assess the risk of your project but worried about that some of the managers involved in the project could affect the outcome of any risk identification meeting. Your consideration is based on the fact that some employees would not want to publicly identify risk events that could declare their supervision as poor. You would like a method that would allow

participants to anonymously identify risk events.

What risk identification method could you use?

- A. Delphi technique
- B. Root cause analysis
- C. Isolated pilot groups
- D. SWOT analysis

88) Which of the following represents lack of adequate controls?

- A. Vulnerability
- B. Threat
- C. Asset
- D. Impact

89) The only output of qualitative risk analysis is risk register updates. When the project manager updates the risk register, he will need to include several pieces of information including all of the following except for which one?

- A. Trends in qualitative risk analysis
- B. Risk probability-impact matrix

- C. Risks grouped by categories
- D. Watchlist of low-priority risks

90) Which of the following risks is the risk that happen with an important business partner and affects a large group of enterprises within an area or industry?

- A. Contagious risk
- B. Reporting risk
- C. Operational risk
- D. Systemic risk

91) You have been assigned as the Project Manager for a new project that involves development of a new interface for your existing time management system. You have completed identifying all possible risks along with the stakeholders and team and have calculated the probability and impact of these risks. Which of the following would you need next to help you prioritize the risks?

- A. Affinity Diagram
- B. Risk rating rules
- C. Project Network Diagram
- D. Risk categories

92) You are the project manager of a large networking project. During the execution phase the customer requests for a change in the existing project plan. What will be your immediate action?

- A. Update the risk register.
- B. Ask for a formal change request.

- C. Ignore the request as the project is in the execution phase.
- D. Refuse the change request.

93) Which of the following is described by the definition given below?

"It is the expected guaranteed value of taking a risk."

- A. Certainty equivalent value
- B. Risk premium
- C. Risk value guarantee
- D. Certain value assurance

94) You are the project manager of GHT project. Your hardware vendor left you a voicemail saying that the delivery of the equipment you have ordered would not arrive on time. She wanted to give you a heads-up and asked that you return the call. Which of the following statements is TRUE?

- A. This is a residual risk.
- B. This is a trigger.
- C. This is a contingency plan.
- D. This is a secondary risk.

95) There are five inputs to the quantitative risk analysis process. Which one of the following is NOT an input to quantitative risk analysis process?

- A. Risk management plan
- B. Enterprise environmental factors

C. Cost management plan

D. Risk register

96) Stephen is the project manager of the GBB project. He has worked with two subject matter experts and his project team to complete the risk assessment technique. There are approximately 47 risks that have a low probability and a low impact on the project.

Which of the following answers best describes what Stephen should do with these risk events?

A. Because they are low probability and low impact, Stephen should accept the risks.

B. The low probability and low impact risks should be added to a watchlist for future monitoring.

C. Because they are low probability and low impact, the risks can be dismissed.

D. The low probability and low impact risks should be added to the risk register.

97) Jenny is the project manager for the NBT projects. She is working with the project team and several subject matter experts to perform the quantitative risk analysis process. During this process she and the project team uncover several risks events that were not previously identified.

What should Jenny do with these risk events?

A. The events should be entered into qualitative risk analysis.

- B. The events should be determined if they need to be accepted or responded to.
- C. The events should be entered into the risk register.
- D. The events should continue on with quantitative risk analysis.

98) You are working on a project in an enterprise. Some part of your project requires e-commerce, but your enterprise choose not to engage in e-commerce. This scenario is demonstrating which of the following form?

- A. risk avoidance
- B. risk treatment
- C. risk acceptance
- D. risk transfer

99) Which of the following are risk components of the COSO ERM framework?

Each correct answer represents a complete solution. Choose three.

- A. Risk response
- B. Internal environment
- C. Business continuity

D. Control activities

100) Your project team has completed the quantitative risk analysis for your project work. Based on their findings, they need to update the risk register with several pieces of information.

Which one of the following components is likely to be updated in the risk register based on their analysis?

A. Listing of risk responses

B. Risk ranking matrix

C. Listing of prioritized risks

D. Qualitative analysis outcomes

101) Fred is the project manager of a large project in his organization. Fred needs to begin planning the risk management plan with the project team and key stakeholders.

Which plan risk management process tool and technique should Fred use to plan risk management?

A. Information gathering techniques

- B. Data gathering and representation techniques
- C. Planning meetings and analysis
- D. Variance and trend analysis

102) Which of the following is the HIGHEST risk of a policy that inadequately defines data and system ownership?

- A. User management coordination does not exist
- B. Audit recommendations may not be implemented
- C. Users may have unauthorized access to originate, modify or delete data
- D. Specific user accountability cannot be established

103) Marie has identified a risk event in her project that needs a mitigation response. Her response actually creates a new risk event that must now be analyzed and planned for.

What term is given to this newly created risk event?

- A. Residual risk
- B. Secondary risk
- C. Infinitive risk
- D. Populated risk

104) Which one of the following is the only output for the qualitative risk analysis process?

- A. Project management plan
- B. Risk register updates
- C. Organizational process assets
- D. Enterprise environmental factors

105) FISMA requires federal agencies to protect IT systems and data.

How often should compliance be audited by an external organization?

- A. Annually
- B. Quarterly
- C. Every three years
- D. Never

106) Which of the following is the FOREMOST root cause of project risk?

Each correct answer represents a complete solution. Choose two.

- A. New system is not meeting the user business needs
- B. Delay in arrival of resources
- C. Lack of discipline in managing the software development process
- D. Selection of unsuitable project methodology

107) You are the project manager of a SGT project. You have been actively communicating and working with the project stakeholders. One of the outputs of the

"Manage stakeholder expectations" process can actually create new risk events for your project.

Which output of the manage stakeholder expectations process can create risks?

- A. Project management plan updates
- B. An organizational process asset update
- C. Change requests
- D. Project document updates

108) Which of the following characteristics of risk controls can be defined as under?

"The separation of controls in the production environment rather than the separation in the design and implementation of the risk"

- A. Trusted source
- B. Secure
- C. Distinct
- D. Independent

109) Shelly is the project manager of the BUF project for her company. In this project Shelly needs to establish some rules to reduce the influence of risk bias during the qualitative risk analysis process.

What method can Shelly take to best reduce the influence of risk bias?

- A. Establish risk boundaries
- B. Group stakeholders according to positive and negative stakeholders and then complete the risk analysis

- C. Determine the risk root cause rather than the person identifying the risk events
- D. Establish definitions of the level of probability and impact of risk event

110) You are the IT manager in Bluewell Inc. You identify a new regulation for safeguarding the information processed by a specific type of transaction.

What would be the FIRST action you will take?

- A. Assess whether existing controls meet the regulation
- B. Update the existing security privacy policy
- C. Meet with stakeholders to decide how to comply
- D. Analyze the key risk in the compliance process

111) You are the risk official of your enterprise. You have just completed

risk analysis process. You noticed that the risk level associated with your project is less than risk tolerance level of your enterprise.

Which of following is the MOST likely action you should take?

- A. Apply risk response
- B. Update risk register
- C. No action
- D. Prioritize risk response options

112) Which of the following operational risks ensures that the provision of a quality product is not overshadowed by the production costs of that product?

- A. Information security risks
- B. Contract and product liability risks
- C. Project activity risks
- D. Profitability operational risks

113) Which of the following is the process of numerically analyzing the effects of identified risks on the overall enterprise's objectives?

- A. Identifying Risks
- B. Quantitative Risk Assessment
- C. Qualitative Risk Assessment
- D. Monitoring and Controlling Risks

114) Which of the following processes is described in the statement below?

"It is the process of exchanging information and views about risks among stakeholders, such as groups, individuals, and institutions."

- A. Risk governance
- B. IRGC
- C. Risk response planning
- D. Risk communication

115) Which of the following are the principles of risk management?

Choose three.

- A. Risk management should be an integral part of the organization
- B. Risk management should be a part of decision-making
- C. Risk management is the responsibility of executive management
- D. Risk management should be transparent and inclusive

116) Which of the following characteristics of risk controls answers the

aspect about the control given below: "Will it continue to function as expressed over the time and adopts as changes or new elements are introduced to the environment"

- A. Reliability
- B. Sustainability
- C. Consistency
- D. Distinct

117) Jeff works as a Project Manager for www.company.com Inc. He and his team members are involved in the identify risk process. Which of the following tools & techniques will Jeff use in the identify risk process? (Choose three.)

- A. Information gathering technique
- B. Documentation reviews
- C. Checklist analysis
- D. Risk categorization

118) Mary is the project manager for the BLB project. She has instructed the project team to assemble, to review the risks. She has included the schedule management plan as an input for the quantitative risk analysis process.

Why is the schedule management plan needed for quantitative risk analysis?

- A. Mary will schedule when the identified risks are likely to happen and affect the project schedule.
- B. Mary will utilize the schedule controls and the nature of the schedule for the quantitative analysis of the schedule.

C. Mary will use the schedule management plan to schedule the risk identification meetings throughout the remaining project.

D. Mary will utilize the schedule controls to determine how risks may be allowed to change the project schedule.

119) Which of the following control detects problem before it can occur?

A. Deterrent control

B. Detective control

C. Compensation control

D. Preventative control

120) Which of the following aspects are included in the Internal Environment Framework of COSO ERM?

Each correct answer represents a complete solution. Choose three.

A. Enterprise's integrity and ethical values

B. Enterprise's working environment

C. Enterprise's human resource standards

D. Enterprise's risk appetite

121) Which of the following type of risk could result in bankruptcy?

- A. Marginal
- B. Negligible
- C. Critical
- D. Catastrophic

122) Risks with low ratings of probability and impact are included for future monitoring in which of the following?

- A. Risk alarm
- B. Observation list
- C. Watch-list
- D. Risk register

123) You are the project manager of your project. You have to analyze various project risks. You have opted for quantitative analysis instead of qualitative risk analysis.

What is the MOST significant drawback of using quantitative analysis over qualitative risk analysis?

- A. lower objectivity
- B. higher cost

- C. higher reliance on skilled personnel
- D. lower management buy-in

124) You are working as the project manager of the ABS project. The project is for establishing a computer network in a school premises. During the project execution, the school management asks to make the campus Wi-Fi enabled. You know that this may impact the project adversely. You have discussed the change request with other stakeholders.

What will be your NEXT step?

- A. Update project management plan.
- B. Issue a change request.
- C. Analyze the impact.
- D. Update risk management plan.

125) Which of the following role carriers are responsible for setting up the risk governance process, establishing and maintaining a common risk view, making risk- aware business decisions, and setting the enterprise's risk culture?

Each correct answer represents a complete solution. Choose two.

- A. Senior management
- B. Chief financial officer (CFO)
- C. Human resources (HR)
- D. Board of directors

126) You are working in an enterprise. Your project deals with important files that are stored on the computer. You have identified the risk of the failure of operations. To address this risk of failure, you have guided the system administrator sign off on the daily backup.

This scenario is an example of which of the following?

- A. Risk avoidance
- B. Risk transference
- C. Risk acceptance
- D. Risk mitigation

127) Risks to an organization's image are referred to as what kind of risk?

- A. Operational
- B. Financial
- C. Information
- D. Strategic

128) Which of the following steps ensure effective communication of the risk analysis results to relevant stakeholders? Choose three.

- A. The results should be reported in terms and formats that are useful to support business decisions
- B. Provide decision makers with an understanding of worst-case and most probable scenarios, due diligence exposures and significant reputation, legal or regulatory considerations

C. Communicate the negative impacts of the events only, it needs more consideration

D. Communicate the risk-return context clearly

129) You are the product manager in your enterprise. You have identified that new technologies, products and services are introduced in your enterprise time-to-time.

What should be done to prevent the efficiency and effectiveness of controls due to these changes?

A. Receive timely feedback from risk assessments and through key risk indicators, and update controls

B. Add more controls

C. Perform Business Impact Analysis (BIA)

D. Nothing, efficiency and effectiveness of controls are not affected by these changes

130) Which of the following are sub-categories of threat?

Each correct answer represents a complete solution. Choose three.

A. Natural and supernatural

B. Computer and user

- C. Natural and man-made
- D. Intentional and accidental
- E. External and internal

131) You work as a project manager for BlueWell Inc. Your project is using a new material to construct a large warehouse in your city. This new material is cheaper than traditional building materials, but it takes some time to learn how to use the material properly. You have communicated to the project stakeholders that you will be able to save costs by using the new material, but you will need a few extra weeks to complete training to use the materials.

This risk response of learning how to use the new materials can also be known as what term?

- A. Benchmarking
- B. Cost-benefits analysis
- C. Cost of conformance to quality
- D. Team development

132) What is the PRIMARY objective difference between an internal and an external risk management assessment reviewer?

- A. In quality of work
- B. In ease of access
- C. In profession
- D. In independence

133) You work as a Project Manager for www.company.com Inc. You have to measure the probability, impact, and risk exposure. Then, you have to measure how the selected risk response can affect the probability and impact of the selected risk event. Which of the following tools will help you to accomplish the task?

- A. Project network diagrams
- B. Delphi technique
- C. Decision tree analysis
- D. Cause-and-effect diagrams

134) Which of the following are external risk factors?

Each correct answer represents a complete solution. Choose three.

- A. Geopolitical situation
- B. Complexity of the enterprise
- C. Market

D. Competition

135) Which of the following is an acceptable method for handling positive project risk?

A. Exploit

B. Avoid

C. Mitigate

D. Transfer

136) You are the project manager of GFT project. Your project involves the use of electrical motor. It was stated in its specification that if its temperature would increase to 500-degree Fahrenheit the machine will overheat and have to be shut down for 48 hours. If the machine overheats even once it will delay the project's arrival date. So, to prevent this you have decided while creating response that if the temperature of the machine reach 450, the machine will be paused for at least an hour so as to normalize its temperature.

This temperature of 450 degrees is referred to as?

A. Risk identification

B. Risk trigger

C. Risk event

D. Risk response

137) Which of the following decision tree nodes have probability attached to their branches?

- A. Root node
- B. Event node
- C. End node
- D. Decision node

138) Which of the following IS processes provide indirect information?

Each correct answer represents a complete solution. Choose three.

- A. Post-implementation reviews of program changes
- B. Security log monitoring
- C. Problem management
- D. Recovery testing

139) You are the risk professional of your enterprise. You need to calculate potential revenue loss if a certain risk occurs. Your enterprise has an electronic (e-commerce) web site that is producing US \$1 million of revenue each day, then if a denial of service (DoS) attack occurs that lasts half a day creates how much loss?

- A. US \$250,000 loss
- B. US \$500,000 loss

- C. US \$1 million loss
- D. US \$100,000 loss

140) Which of the following process ensures that extracted data are ready for analysis?

- A. Data analysis
- B. Data validation
- C. Data gathering
- D. Data access

141) Which of the following vulnerability assessment software can check for weak passwords on the network?

- A. Password cracker
- B. Antivirus software
- C. Anti-spyware software
- D. Wireshark

142) Which of the following is NOT true for risk governance?

- A. Risk governance is based on the principles of cooperation, participation, mitigation and sustainability, and is adopted to achieve more effective risk management.
- B. Risk governance requires reporting once a year.
- C. Risk governance seeks to reduce risk exposure and vulnerability by filling gaps in risk policy.
- D. Risk governance is a systemic approach to decision making processes associated to natural and technological risks.

143) You are the project manager of HGT project. You have identified project risks and applied appropriate response for its mitigation. You noticed a risk generated as a result of applying response.

What this resulting risk is known as?

- A. Pure risk

- B. Secondary risk
- C. Response risk
- D. High risk

144) What are the various outputs of risk response? (Choose 3)

- A. Risk Priority Number
- B. Residual risk
- C. Risk register updates
- D. Project management plan and Project document updates
- E. Risk-related contract decisions

145) Which of the following is an output of risk assessment process?

- A. Identification of risk
- B. Identification of appropriate controls
- C. Mitigated risk
- D. Enterprise left with residual risk

146) What is the IMMEDIATE step after defining set of risk scenarios?

- A. Risk mitigation
- B. Risk monitoring
- C. Risk management

D. Risk analysis

147) Which of the following statements are true for risk communication?

Each correct answer represents a complete solution. Choose three.

- A. It requires a practical and deliberate scheduling approach to identify stakeholders, actions, and concerns.
- B. It helps in allocating the information concerning risk among the decision-makers.
- C. It requires investigation and interconnectivity of procedural, legal, social, political, and economic factors.
- D. It defines the issue of what a stakeholder does, not just what it says.

148) Which of the following is the most accurate definition of a project risk?

- A. It is an unknown event that can affect the project scope.

- B. It is an uncertain event or condition within the project execution.
- C. It is an uncertain event that can affect the project costs.
- D. It is an uncertain event that can affect at least one project objective.

149) Which of the following considerations should be taken into account while selecting risk indicators that ensures greater buy-in and ownership?

- A. Lag indicator
- B. Lead indicator
- C. Root cause
- D. Stakeholder

150) Suppose you are working in Techmart Inc. which sells various products through its website. Due to some recent losses, you are trying to identify the most important risks to the Website. Based on feedback from several experts, you have come up with a list. You now want to prioritize these risks.

Now in which category you would put the risk concerning the modification of the Website by unauthorized parties.

- A. Ping Flooding Attack
- B. Web defacing
- C. Denial of service attack
- D. FTP Bounce Attack

Answers & Explanation:

1) Correct Answer: D

Threats and vulnerabilities change over time and KRI maintenance ensures that KRIs continue to effectively capture these changes.

The risk environment is highly dynamic as the enterprise's internal and external environments are constantly changing. Therefore, the set of KRIs needs to be changed over time, so that they can capture the changes in threat and vulnerability.

Incorrect Answers:

A: Risk avoidance is one possible risk response. Risk responses are based on KRI reporting, but is not the reason for maintenance of KRIs.

B: While most key risk indicator (KRI) metrics need to be optimized in respect to their sensitivity, the most important objective of KRI maintenance is to ensure that

KRIs continue to effectively capture the changes in threats and vulnerabilities over time. Hence the most important reason is that because of change of threat and vulnerability overtime.

C: Risk reporting timeliness is a business requirement, but is not a reason for KRI maintenance.

2) Correct Answer: C

The risk responses that do not exist up till then, should be included in the organization's lessons learned database so other project managers can use these responses in their project if relevant.

Incorrect Answers:

A: The responses are not in the project management plan, but in the risk response plan during the project and they'll be entered into the organization's lessons learned database.

B: The risk responses are included in the risk response plan, but after completing the project, they should be entered into the organization's lessons learned database.

D: If the new responses that were identified is only included in the project's risk register, then it may not be shared with project managers working on some other project.

3) Correct Answer: D

This risk event has the potential to save money on project costs, so it is an opportunity, and the appropriate strategy to use in this case is the exploit strategy. The exploit response is one of the strategies to negate risks or threats appear in a project. This strategy may be selected for risks with positive impacts where the organization wishes to ensure that the opportunity is realized. Exploiting a risk event provides opportunities for positive impact on a project. Assigning more talented resources to the project to reduce the time to completion is an example of exploit response.

Incorrect Answers:

A, C: Mitigation and avoidance risk response is used in case of negative risk events, and not in positive risk events. Here in this scenario, as it is stated that the event could save \$100,000, hence it is a positive risk event. Therefore, should not be mitigated or avoided.

B: To accept risk means that no action is taken relative to a particular risk; loss is accepted if it occurs. But as this risk event bring an opportunity, it should be exploited and not accepted.

4) Correct Answer: C

Risk identification is an iterative process because new risks may evolve or become known as the project progresses through its life cycle.

Incorrect Answers:

A: Stakeholders are encouraged to participate in the risk identification process, but this is not the best choice.

B: Risk identification focuses on discovering new risk events, not the events which did not happen.

D: The primary reason for iterations of risk identification is to identify new risk events.

5) Correct Answer: A

Steps involving in calculating risk priority number are as follows:

- ☞ Identify potential failure effects
- ☞ Identify potential causes
- ☞ Establish links between each identified potential cause
- ☞ Identify potential failure modes
- ☞ Assess severity, occurrence and detection
- ☞ Perform score assessments by using a scale of 1 -10 (low to high rating) to score these assessments.
- ☞ Compute the RPN for a particular failure mode as Severity multiplied by occurrence and detection.

$$\text{RPN} = \text{Severity} * \text{Occurrence} * \text{Detection}$$

Hence,

$$\text{RPN} = 4 * 5 * 6 -$$

$$= 120$$

Incorrect Answers:

B, C, D: These are not RPN for given values of severity, occurrence, and detection.

6) Correct Answer: B

Key Risk Indicators are the prime monitoring indicators of the enterprise. KRIs are highly relevant and possess a high probability of predicting or indicating important risk. KRIs help in avoiding excessively large number of risk indicators to manage and report that a large enterprise may have.

As KRIs are the indicators of risk, hence its most important function is to effectively give an early warning signal that a high risk is emerging to enable management to take proactive action before the risk actually becomes a loss.

Incorrect Answers:

A: This is one of the important functions of KRIs which can help management to improve but is not as important as giving early warning.

C: KRIs provide an indication of the enterprise's risk appetite and tolerance through metric setting, but this is not as important as giving early warning.

D: This is not as important as giving early warning.

7) Correct Answer: AB

An enterprise may have hundreds of risk indicators such as logs, alarms and reports. The CRISC will usually need to work with senior management and

business leaders to determine which risk indicators will be monitored on a regular basis and be recognized as KRIs.

Incorrect Answers:

C, D: Chief financial officer and human resource only overview common risk view, but are not involved in risk-based decisions.

8) Correct Answer: BCD

Creating a scenario requires determination of the value of an asset or a business process at risk and the potential threats and vulnerabilities that could cause loss.

The risk scenario should be assessed for relevance and realism, and then entered into the risk register if found to be relevant.

In practice following steps are involved in risk scenario development:

- ☞ First determine manageable set of scenarios, which include:
 - Frequently occurring scenarios in the industry or product area.
 - Scenarios representing threat sources that are increasing in count or severity level.
 - Scenarios involving legal and regulatory requirements applicable to the business.
- ☞ After determining manageable risk scenarios, perform a validation against the business objectives of the entity.
- ☞ Based on this validation, refine the selected scenarios and then detail them to a level in line with the criticality of the entity.
- ☞ Lower down the number of scenarios to a manageable set. Manageable does not signify a fixed number, but should be in line with the overall importance and criticality of the unit.
- ☞ Risk factors kept in a register so that they can be reevaluated in the next

iteration and included for detailed analysis if they have become relevant at that time.

☞ Risk factors kept in a register so that they can be reevaluated in the next iteration and included for detailed analysis if they have become relevant at that time.

☞ Include an unspecified event in the scenarios, that is, address an incident not covered by other scenarios.

Incorrect Answers:

A: Cause-and-effect analysis is a predictive or diagnostic analytical tool used to explore the root causes or factors that contribute to positive or negative effects or outcomes. It is used during the process of exposing risk factors.

9) Correct Answer: D

The Communications Management Plan defines, in regard to risk management, who will be available to share information on risks and responses throughout the project.

The Communications Management Plan aims to define the communication necessities for the project and how the information will be circulated. The

Communications Management Plan sets the communication structure for the project. This structure provides guidance for communication throughout the project's life and is updated as communication needs change. The Communication Managements Plan identifies and defines the roles of persons concerned with the project. It includes a matrix known as the communication matrix to map the communication requirements of the project.

Incorrect Answers:

A: The Resource Management Plan does not define risk communications.

B: The Risk Management Plan defines risk identification, analysis, response,

and monitoring.

C: The stakeholder management strategy does not address risk communications.

10) Correct Answer: B

Physical security is an example of non-technical control. It comes under the family of operational controls.

Incorrect Answers:

A, C, D: Intrusion detection system, access control, and encryption are the safeguards that are incorporated into computer hardware, software or firmware; hence they refer to as technical controls.

11) Correct Answer: D

Decision tree diagrams are used during the Quantitative risk analysis process and not in risk identification.

Incorrect Answers:

A, B, C: All these options are diagrammatical techniques used in the Identify risks process.

12) Correct Answer: D

The utility of the risk describes the usefulness of a particular risk to an individual. Moreover, the same risk can be utilized by two individuals in different ways.

Financial outcomes are one of the methods for measuring potential value for taking a risk. For example, if the individual's economic wealth increases, the

potential utility of the risk will decrease.

Incorrect Answers:

A: Determining financial incentive is one of the methods to measure the potential value for taking a risk, but it is not the valid definition for utility of risk.

B: It is not the valid definition.

C: It is not the valid definition.

13) Correct Answer: A

Monitoring tools have to be able to keep up with the growth of an enterprise and meet anticipated growth in process, complexity or transaction volumes; this is ensured by the scalability criteria of the monitoring tool.

Incorrect Answers:

B: For software to be effective, it must be customizable to the specific needs of an enterprise. Hence customizability ensures that end users can adapt the software.

C: It ensures that monitoring software is able to change at the same speed as technology applications and infrastructure to be effective over time.

D: The impact on performance has nothing related to the ability of monitoring tool to keep up with the growth of enterprise.

14) Correct Answer: A

Moderate risks are noticeable failure threatening the success of certain goals.

Incorrect Answers:

B: High risk is the significant failure impacting in certain goals not being met.

C: Extremely high risk are the risks that has large impact on enterprise and are most likely results in failure with severe consequences.

D: Low risks are the risk that results in certain unsuccessful goals.

15) Correct Answer: B

By grouping the risks by categories, the project team can develop effective risk responses. Related risk events often have common causal factors that can be addressed with a single risk response.

16) Correct Answer: D

Risk communication is the process of exchanging information and views about risks among stakeholders, such as groups, individuals, and institutions. Risk communication is mostly concerned with the nature of risk or expressing concerns, views, or reactions to risk managers or institutional bodies for risk management. The key plan to consider and communicate risk is to categorize and impose priorities, and acquire suitable measures to reduce risks. It is important throughout any crisis to put across multifaceted information in a simple and clear manner.

Risk communication helps in switching or allocating the information concerning risk among the decision-maker and the stakeholders. Risk communication can be explained more clearly with the help of the following definitions:

- ☞ It defines the issue of what a group does, not just what it says.
- ☞ It must take into account the valuable element in user's perceptions of risk.
- ☞ It will be more valuable if it is thought of as conversation, not instruction.

Risk communication is a fundamental and continuing element of the risk analysis exercise, and the involvement of the stakeholder group is from the beginning. It makes the stakeholders conscious of the process at each phase

of the risk assessment. It helps to guarantee that the restrictions, outcomes, consequence, logic, and risk assessment are undoubtedly understood by all the stakeholders.

Incorrect Answers:

C: A risk response ensures that the residual risk is within the limits of the risk appetite and tolerance of the enterprise. Risk response is process of selecting the correct, prioritized response to risk, based on the level of risk, the enterprise's risk tolerance and the cost and benefit of the particular risk response option.

Risk response ensures that management is providing accurate reports on:

The level of risk faced by the enterprise

☞ The incidents' type that have occurred

☞ Any alteration in the enterprise's risk profile based on changes in the risk environment.

17) Correct Answer: A

The primary outputs from Identify Risks are the initial entries into the risk register. The risk register ultimately contains the outcomes of other risk management processes as they are conducted, resulting in an increase in the level and type of information contained in the risk register over time.

Incorrect Answers:

B, C, D: All these are outputs from the "Plan Risk Management" process, which happens prior to the starting of risk identification.

18) Correct Answer: D

Components of risk scenario that are needed for its analysis are:

- ☞ Actor: Actors are those components of risk scenario that has the potential to generate the threat that can be internal or external, human or non-human. Internal actors are within the enterprise like staff, contractors, etc. On the other hand, external factors include outsiders, competitors, regulators and the market.
- ☞ Threat type: Threat type defines the nature of threat, that is, whether the threat is malicious, accidental, natural or intentional.
- ☞ Event: Event is an essential part of a scenario; a scenario always has to contain an event. Event describes the happenings like whether it is a disclosure of confidential information, or interruption of a system or project, or modification, theft, destruction, etc.
- ☞ Asset: Assets are the economic resources owned by business or company. Anything tangible or intangible that one possesses, usually considered as applicable to the payment of one's debts, is considered an asset. An asset can also be defined as a resource, process, product, computing infrastructure, and so forth that an organization has determined must be protected. Tangible asset: Tangible are those assets that has physical attributes and can be detected with the senses, e.g., people, infrastructure, and finances. Intangible asset: Intangible are those assets that has no physical attributes and cannot be detected with the senses, e.g., information, reputation and customer trust.
- ☞ Timing dimension: The timing dimension is the application of the scenario to detect time to respond to or recover from an event. It identifies if the event occurs at a critical moment and its duration. It also specifies the time lag between the event and the consequence, that is, if there an immediate consequence (e.g., network failure, immediate downtime) or a delayed consequence (e.g., wrong IT architecture with accumulated high costs over a long period of time).

19) Correct Answer: AC

Pilot testing and reviewing of performance data to verify operation against design are done before relying on control.

Incorrect Answers:

B: Discovering risk exposure helps in identifying the severity of risk, but it does not play any role in specifying the reliability of control.

D: Articulating risk is the first phase in the risk response process to ensure that information on the true state of exposures and opportunities are made available in a timely manner and to the right people for appropriate response. But it does not play any role in identifying whether any specific control is reliable or not.

20) Correct Answer: B

The enterprise with risk management capability maturity level 0 makes decisions without having much knowledge about the risk credible information. In level 1, enterprise takes decisions on the basis of risk credible information.

Incorrect Answers:

A, C, D: An enterprise's risk management capability maturity level is 1 when:

- ☞ There is an understanding that risk is important and needs to be managed, but it is viewed as a technical issue and the business primarily considers the downside of IT risk.

- ☞ Any risk identification criteria vary widely across the enterprise.

- ☞ Risk appetite and tolerance are applied only during episodic risk assessments.

- ☞ Enterprise risk policies and standards are incomplete and/or reflect only external requirements and lack defensible rationale and enforcement mechanisms.

- ☞ Risk management skills exist on an ad hoc basis, but are not actively developed.

- ☞ Ad hoc inventories of controls that are unrelated to risk are dispersed

across desktop applications.

21) Correct Answer: D

Business managers are accountable for managing the associated risk and will determine what actions to take based on the information provided by others.

Incorrect Answers:

A: Information security managers may best understand the technical tactical situation, but business managers are accountable for managing the associated risk and will determine what actions to take based on the information provided by others, which includes collaboration with, and support from, IT security managers.

C: The incident response team must ensure open communication to management and stakeholders to ensure that business managers understand the associated risk and are provided enough information to make informed risk-based decisions. They are not responsible for reviewing risk response options.

22) Correct Answer: C

Fault tree analysis (FTA) is a technique that provides a systematic description of the combination of possible occurrences in a system, which can result in an undesirable outcome. It combines hardware failures and human failures.

Incorrect Answers:

A: Sensitivity analysis is the quantitative risk analysis technique that:

Assist in determination of risk factors that have the most potential impact
Examines the extent to which the uncertainty of each element affects the object under consideration when all other uncertain elements are held at their baseline values

B: This analysis provides ability to see a range of values across several scenarios to identify risk in specific situation. It provides ability to identify those inputs which will provide the greatest level of uncertainty.

D: Cause-and-effect analysis involves the use of predictive or diagnostic analytical tool for exploring the root causes or factors that contribute to positive or negative effects or outcomes. These tools also help in identifying potential risk.

23) Correct Answer: A

The process for selecting and implementing measures for impacting risk in the environment is called risk treatment.

Incorrect Answers:

C: The process of analyzing and evaluating risk is called risk assessment.

D: Risk management is the coordinated activities for directing and controlling the treatment of risk in the organization.

24) Correct Answer: A

Section 302 of the Sarbanes-Oxley Act requires corporate responsibility for financial reports to be certified by CEO, CFO, or designated representative.

Incorrect Answers:

B: Section 404 of the Sarbanes-Oxley Act states that annual assessments of internal controls are the responsibility of management.

C: Section 203 of the Sarbanes-Oxley Act requires audit partners and review partners to rotate off an assignment every five years.

D: Section 409 of the Sarbanes-Oxley Act states that the financial reports must be distributed quickly and currently.

25) Correct Answer: C

Controls can be effectively assessed only by determining how accurately the control objective is achieved within the environment in which they are operating. No conclusion can be reached as to the strength of the control until the control has been adequately tested.

Incorrect Answers:

A: Alignment of control with the operating environment is essential but after the control's accuracy in achieving objective. In other words, achieving objective is the top most priority in assessing controls.

B: Control's design effectiveness is also considered but is latter considered after achieving objectives.

D: Control's operating effectiveness is considered but after its accuracy in objective achievement.

26) Correct Answer: D

Fast tracking allows entire phases of the project to overlap and generally increases risks within the project.

Fast tracking is a technique for compressing project schedule. In fast tracking, phases are overlapped that would normally be done in sequence. It is shortening the project schedule without reducing the project scope.

Incorrect Answers:

A: Human resources are not affected by fast tracking in most scenarios.

B: Quality control concerns usually are not affected by fast tracking decisions.

C: Costs do not generally increase based on fast tracking decisions.

27) Correct Answer: B

As David is taking some operational controls to reduce the likelihood and impact of the risk, hence he is adopting risk mitigation. Risk mitigation means that actions are taken to reduce the likelihood and/or impact of risk.

Incorrect Answers:

A: Risk avoidance means that activities or conditions that give rise to risk are discontinued. But here, no such actions are taken, therefore risk is not avoided.

C: Risk acceptance means that no action is taken relative to a particular risk; loss is accepted in case it occurs. As David has taken some actions in case to defend, therefore he is not accepting risk.

D: David has not hired a vendor to manage the risk for his project; therefore, he is not transferring the risk.

28) Correct Answer: A

The basic purpose of Information System control in an organization is to ensure that the business objectives are achieved and undesired risk events are detected and corrected. Some of the IS control objectives are given below:

- ☞ Safeguarding assets
- ☞ Assuring integrity of sensitive and critical application system environments
- ☞ Assuring integrity of general operating system
- ☞ Ensuring effective and efficient operations
- ☞ Fulfilling user requirements, organizational policies and procedures, and applicable laws and regulations

- ☞ Changing management
- ☞ Developing business continuity and disaster recovery plans
- ☞ Developing incident response and handling plans

Hence the most important objective is to ensure that business objectives are achieved and undesired risk events are detected and corrected.

Incorrect Answers:

B, C, D: These are also the objectives of the information system control but are not the best answer.

29) Correct Answer: A

The Business Continuity Strategy is an outline of the approach to ensure the continuity of Vital Business Functions in the case of disaster events. The Business

Continuity Strategy is prepared by the business and serves as a starting point for producing the IT Service Continuity Strategy.

Incorrect Answers:

B: Index of Disaster-Relevant Information is a catalog of all information that is relevant in the event of disasters. This document is maintained and circulated by IT

Service Continuity Management to all members of IT staff with responsibilities for fighting disasters.

C: Disaster Invocation Guideline is a document produced by IT Service Continuity Management with detailed instructions on when and how to invoke the procedure for fighting a disaster. Most importantly, the guideline defines the first step to be taken by the Service Desk after learning that a disaster has occurred.

D: Availability/ ITSCM/ Security Testing Schedule is a schedule for the regular testing of all availability, continuity, and security mechanisms jointly maintained by

Availability, IT Service Continuity, and IT Security Management.

30) Correct Answer: C

An enterprise's risk management capability maturity level is 5 when real-time monitoring of risk events and control exceptions exists, as does automation of policy management.

Incorrect Answers:

A, D: In these levels real-time monitoring of risk events is not done.

B: In level 0 of risk management capability maturity model, enterprise does not recognize the importance of considering the risk management or the business impact from IT risk.

31) Correct Answer: A

Cost performance index (CPI) is used to calculate performance efficiencies of project. It is used in trend analysis to predict future performance. CPI is the ratio of earned value to actual cost.

If the CPI value is greater than 1, it indicates better than expected performance, whereas if the value is less than 1, it shows poor performance.

Incorrect Answers:

B: CPI is the ratio of earned value to actual cost, i.e., $CPI = \text{Earned Value (EV)} / \text{Actual Cost (AC)}$.

C: Cost performance index (CPI) is used to calculate performance efficiencies of project and not its schedule.

D: The CPI value of 1 indicates that the project is right on target.

32) Correct Answer: A

Information about the propriety of cutoff is a kind of direct information.

Incorrect Answers:

B: Reports that show orders that were rejected for credit limitations provide indirect information that credit checking aspects of the system are working as intended.

C: Reports that provide information about any unusual deviations and individual product margins (whereby, the price of an item sold is compared to its standard cost) provide indirect information that controls over billing and pricing are operating.

D: The lack of any significant differences between perpetual levels and actual levels provides indirect information that its billing controls are operating.

33) Correct Answer: A

A salience model defines and charts stakeholders' power, urgency, and legitimacy in the project.

The salience model is a technique for categorizing stakeholders according to their importance. The various difficulties faced by the project managers are as follows:

- ☞ How to choose the right stakeholders?

- ☞ How to prioritize competing claims of the stakeholder's communication needs?

Stakeholder salience is determined by the evaluation of their power, legitimacy and urgency in the organization.

- ☞ Power is defined as the ability of the stakeholder to impose their will.

- ☞ Urgency is the need for immediate action.
- ☞ Legitimacy shows the stakeholders participation is appropriate or not.

The model allows the project manager to decide the relative salience of a particular stakeholder.

Incorrect Answers:

B: This defines the power/interest grid.

C: This defines an influence/impact grid.

D: This defines a power/influence grid.

34) Correct Answer: A

Asset identification is the most crucial and first step in the risk assessment process. Risk identification, assessment and evaluation (analysis) should always be clearly aligned to assets. Assets can be people, processes, infrastructure, information or applications.

35) Correct Answer: A

Risk indicators are metrics used to indicate risk thresholds, i.e., it gives indication when a risk level is approaching a high or unacceptable level of risk. The main objective of a risk indicator is to ensure tracking and reporting mechanisms that alert staff about the potential risks.

Incorrect Answers:

B, D: Estimation of risk's consequence and priority for awareness is conducted by using probability and impact matrix. These matrices specify the mixture of probability and impact that directs to rating the risks as low, moderate, or high priority.

C: A risk scenario is a description of an event that can lay an impact on business, when and if it would occur.

Some examples of risk scenario are of:

- ☞ Having a major hardware failure.
- ☞ Failed disaster recovery planning (DRP).
- ☞ Major software failure.

36) Correct Answer: AD

Risk appetite is the amount of risk a company or other entity is willing to accept in pursuit of its mission. This is the responsibility of the board to decide risk appetite of an enterprise. When considering the risk appetite levels for the enterprise, the following two major factors should be taken into account:

The enterprise's objective capacity to absorb loss, e.g., financial loss, reputation damage, etc.

The culture towards risk taking-cautious or aggressive. In other words, the amount of loss the enterprise wants to accept in pursue of its objective fulfillment.

Incorrect Answers:

B: Alignment with risk-culture is also one of the factors but is not as important as these two.

C: Risk aware decision is not the factor, but is the result which uses risk appetite information as its input.

37) Correct Answer: B

The risk monitoring and controlling is responsible for identifying new risks, determining the status of risks that may have changed, and determining

which risks may be outdated in the project.

Incorrect Answers:

A: Risk planning creates the risk management plan and determines how risks will be identified, analyzed, monitored and controlled, and responded to.

C: Risk identification is a process that identifies risk events in the project.

D: Risk analysis helps determine the severity of the risk events, the risks' priority, and the probability and impact of risks.

38) Correct Answer: B

The Single Loss Expectancy (SLE) of this project will be \$31,250.

Single Loss Expectancy is a term related to Quantitative Risk Assessment. It can be defined as the monetary value expected from the occurrence of a risk on an asset. It is mathematically expressed as follows:

Single Loss Expectancy (SLE) = Asset Value (AV) * Exposure Factor (EF)
where the Exposure Factor represents the impact of the risk over the asset, or percentage of asset lost. As an example, if the Asset Value is reduced two third, the exposure factor value is .66. If the asset is completely lost, the Exposure Factor is 1.0. The result is a monetary value in the same unit as the Single Loss

Expectancy is expressed.

Therefore,

$SLE = \text{Asset Value} * \text{Exposure Factor}$

$= 125,000 * 0.25$

$= \$31,250$

Incorrect Answers:

A, C, D: These are not SLEs of this project.

39) Correct Answer: ABD

The principles of access controls focus on availability, integrity, and confidentiality, as loss or danger is directly related to these three:

☞ Loss of confidentiality- Someone sees a password or a company's secret formula; this is referred to as loss of confidentiality.

☞ Loss of integrity- An e-mail message is modified in transit, a virus infects a file, or someone makes unauthorized changes to a Web site is referred to as loss of integrity.

☞ Loss of availability- An e-mail server is down and no one has e-mail access, or a file server is down so data files aren't available comes under loss of availability.

40) Correct Answer: C

Since the enterprise's internal and external environments are constantly changing, the risk environment is also highly dynamic, i.e., threats and vulnerabilities change over time. Hence KRIs need to be maintained to ensure that KRIs continue to effectively capture these changes.

Incorrect Answers:

A: Timely risk reporting is one of the business requirements, but is not the reason behind KRI maintenance.

B: While most key risk indicator metrics need to be optimized in respect to their sensitivity, the most important objective of KRI maintenance is to ensure that KRIs continue to effectively capture the changes in threats and vulnerabilities over time.

D: Avoiding risk is a type of risk response. Risk responses are based on KRI reporting.

41) Correct Answer: A

Program Management control comes under management class of controls, not technical.

Program Management control is driven by the Federal Information Security Management Act (FISMA). It provides controls to ensure compliance with FISMA.

These controls complement other controls. They don't replace them.

Incorrect Answers:

B, C, D: These controls come under technical class of control.

The Technical class of controls includes four families. These families include over 75 individual controls. Following is a list of each of the families in the technical class:

☞ Access Control (AC): This family of controls helps an organization implement effective access control. They ensure that users have the rights and permissions they need to perform their jobs, and no more. It includes principles such as least privilege and separation of duties.

☞ Audit and Accountability (AU): This family of controls helps an organization implement an effective audit program. It provides details on how to determine what to audit. It provides details on how to protect the audit logs. It also includes information on using audit logs for non-repudiation.

Identification and Authentication (IA): These controls cover different practices to identify and authenticate users. Each user should be uniquely identified. In

other words, each user has one account. This account is only used by one user. Similarly, device identifiers uniquely identify devices on the network.

☞ System and Communications Protection (SC): The SC family is a large group of controls that cover many aspects of protecting systems and

communication channels. Denial of service protection and boundary protection controls are included. Transmission integrity and confidentiality controls are also included.

42) Correct Answer: C

Mary is using brainstorming in this example. Brainstorming attempts to create a comprehensive list of risks and often is led by a moderator or facilitator to move the process along.

Brainstorming is a technique to gather general data. It can be used to identify risks, ideas, or solutions to issues by using a group of team members or subject-matter expert. Brainstorming is a group creativity technique that also provides other benefits, such as boosting morale, enhancing work enjoyment, and improving team work.

Incorrect Answers:

A: The Delphi technique uses rounds of anonymous surveys to generate a consensus on the identified risks.

B: Expert judgment is not the best answer for this; projects experts generally do the risk identification, in addition to the project team.

D: Checklist analysis uses historical information and information from similar projects within the organization's experience.

43) C

In this context, "program" is not the computer program but the program consists of projects.

44) Correct Answer: D

The risk management plan, part of the comprehensive management plan,

defines how risks will be identified, analyzed, monitored and controlled, and even responded to.

A Risk management plan is a document arranged by a project manager to estimate the effectiveness, predict risks, and build response plans to mitigate them. It also consists of the risk assessment matrix.

Risks are built in with any project, and project managers evaluate risks repeatedly and build plans to address them. The risk management plan consists of analysis of possible risks with both high and low impacts, and the mitigation strategies to facilitate the project and avoid being derailed through which the common problems arise. Risk management plans should be timely reviewed by the project team in order to avoid having the analysis become stale and not reflective of actual potential project risks. Most critically, risk management plans include a risk strategy for project execution.

Incorrect Answers:

A: The project plan is not an official PMBOK project management plan.

B: The resource management plan defines the management of project resources, such as project team members, facilities, equipment, and contractors.

C: The project management plan is a comprehensive plan that communicates the intent of the project for all project management knowledge areas.

45) Correct Answer: D

All risks, their responses, and other characteristics are documented in the risk register. As the project progresses and the conditions of the risk events change, the risk register should be updated to reflect the risk conditions.

Incorrect Answers:

A: The risk management plan addresses the project management's approach

to risk management, risk identification, analysis, response, and control.

B: The project management plan is the overarching plan for the project, not the specifics of the risk responses and risk identification.

C: The risk response plan only addresses the planned risk responses for the identified risk events in the risk register.

46) Correct Answer: A

When you are hiring a third party to own risk, it is known as transference risk response.

Risk transfer means that impact of risk is reduced by transferring or otherwise sharing a portion of the risk with an external organization or another internal entity.

Transfer of risk can occur in many forms but is most effective when dealing with financial risks. Insurance is one form of risk transfer.

Incorrect Answers:

B: The act of spending money to reduce a risk probability and impact is known as mitigation.

C: When extra activities are introduced into the project to avoid the risk, this is an example of avoidance.

D: Exploit is a strategy that may be selected for risks with positive impacts where the organization wishes to ensure that the opportunity is realized.

47) Correct Answer: A

The activity duration estimates review is valuable in identifying risks associated to the time allowances for the activities or projects as a whole, with a width of the range indicating the degrees of risk.

Incorrect Answers:

B: The activity cost estimates review is valuable in identifying risks as it provides a quantitative assessment of the expected cost to complete scheduled activities and is expressed as a range, with a width of the range indicating the degrees of risk.

C: A Risk management plan is a document arranged by a project manager to estimate the effectiveness, predict risks, and build response plans to mitigate them.

It also consists of the risk assessment matrix.

D: It describes how the schedule contingencies will be reported and assessed.

48) Correct Answer: BCD

Loss of integrity refers to the following types of losses:

- ☞ An e-mail message is modified in transit A virus infects a file
- ☞ Someone makes unauthorized changes to a Web site

Incorrect Answers:

A: Someone sees company's secret formula or password comes under loss of confidentiality.

49) Correct Answer: C

Review of the enterprise's strategic plan is the first step in designing effective IS controls that would fit the enterprise's long-term plans.

Incorrect Answers:

A: The IT strategic plan exists to support the enterprise's strategic plan but is not solely considered while designing information system control.

B: Review of the existing IT environment is also useful and necessary but is not the first step that needs to be undertaken.

D: The present IT budget is just one of the components of the strategic plan.

50) Correct Answer: C

Blame culture should be avoided. It is the most effective inhibitor of relevant and efficient communication. In a blame culture, business units tend to point the finger at IT when projects are not delivered on time or do not meet expectations. In doing so, they fail to realize how the business unit's involvement up front affects project success. In extreme cases, the business unit may assign blame for a failure to meet the expectations that the unit never clearly communicated. Executive leadership must identify and quickly control a blame culture if collaboration is to be fostered throughout the enterprise.

Incorrect Answers:

A: This is the consequence of poor risk communication, not the inhibitor of effective communication.

B: This is the consequence of poor risk communication, not the inhibitor of effective communication.

D: Misalignment between real risk appetite and translation into policies is an inhibitor of effective communication, but is not as prominent as existence of blame culture.

51) Correct Answer: C

Low-impact, low-probability risks can be added to the low priority risk watch list.

Incorrect Answers:

A: These risks are not dismissed; they are still documented on the low priority risk watch list.

B: While these risks may be accepted, they should be documented on the low priority risk watch list. This list will be periodically reviewed and the status of the risks may change.

D: Not every risk demands a risk response, so this choice is incorrect.

52) Correct Answer: A

An intrusion detection system (IDS) is a device or software application that monitors network and/or system activities for malicious activities or policy violations and produces reports to a Management Station. Some systems may attempt to stop an intrusion attempt but this is neither required nor expected of a monitoring system. Intrusion detection and prevention systems (IDPS) are primarily focused on identifying possible incidents, logging information about them, and reporting attempts. In addition, organizations use IDPS for other purposes, such as identifying problems with security policies, documenting existing threats, and deterring individuals from violating security policies.

As IDS detects and gives warning when the violation of security policies of the enterprise occurs, it is a detective control.

Incorrect Answers:

B: These controls make effort to reduce the impact of a threat from problems discovered by detective controls. As IDS only detects but not reduce the impact, hence it is not a corrective control.

C: As IDS only detects the problem when it occurs and not prior of its occurrence, it is not preventive control.

D: These controls make efforts to overcome the impact of the incident on the business, hence IDS is not a recovery control.

53) Correct Answer: ACD

Audit and accountability family of controls helps an organization implement an effective audit program. It provides details on how to determine what to audit. It provides details on how to protect the audit logs. It also includes information on using audit logs for non-repudiation.

Incorrect Answers:

B: Access Control is the family of controls that helps an organization implement effective access control. They ensure that users have the rights and permissions they need to perform their jobs, and no more. It includes principles such as least privilege and separation of duties.

Audit and accountability family of controls do not help in implementing effective access control.

54) Correct Answer: B

The risk response process is triggered when a risk exceeds the enterprise's risk tolerance level. The acceptable variation relative to the achievement of an objective is termed as risk tolerance. In other words, risk tolerance is the acceptable deviation from the level set by the risk appetite and business objectives.

Risk tolerance is defined at the enterprise level by the board and clearly communicated to all stakeholders. A process should be in place to review and approve any exceptions to such standards.

Incorrect Answers:

A, C: Risk appetite level is not relevant in triggering of risk response process. Risk appetite is the amount of risk a company or other entity is willing to accept in pursuit of its mission. This is the responsibility of the board to decide risk appetite of an enterprise. When considering the risk appetite levels for the enterprise, the following two major factors should be taken into

account:

- ☞ The enterprise's objective capacity to absorb loss, e.g., financial loss, reputation damage, etc.
- ☞ The culture towards risk taking-cautious or aggressive. In other words, the amount of loss the enterprise wants to accept in pursue of its objective fulfillment.

D: Risk response process is triggered when the risk level increases the risk tolerance level of the enterprise, and not when it just equates the risk tolerance level.

55) Correct Answer: A

Exposure Factor represents the impact of the risk over the asset, or percentage of asset lost. For example, if the Asset Value is reduced to two third, the exposure factor value is 0.66.

Therefore, when the asset is completely lost, the Exposure Factor is 1.0.

Incorrect Answers:

B, C, D: These are not the values of exposure factor for zero assets.

56) Correct Answer: D

This is an example of exploiting a positive risk - a by-product of a project is an excellent example of exploiting a risk. Exploit response is one of the strategies to negate risks or threats that appear in a project. This strategy may be selected for risks with positive impacts where the organization wishes to ensure that the opportunity is realized. Exploiting a risk event provides opportunities for positive impact on a project. Assigning more talented resources to the project to reduce the time to completion is an example of exploit response.

Incorrect Answers:

A: Enhancing is a positive risk response that describes actions taken to increase the odds of a risk event to happen.

B: This is an example of a positive risk, but positive is not a risk response.

C: Opportunistic is not a valid risk response.

57) Correct Answer: D

A quantitative risk assessment quantifies risk in terms of numbers such as dollar values. This involves gathering data and then entering it into standard formulas.

The results can help in identifying the priority of risks. These results are also used to determine the effectiveness of controls. Some of the terms associated with quantitative risk assessments are:

☞ Single loss expectancy (SLE)-It refers to the total loss expected from a single incident. This incident can occur when vulnerability is being exploited by threat.

The loss is expressed as a dollar value such as \$1,000. It includes the value of data, software, and hardware. $SLE = \text{Asset value} * \text{Exposure factor}$

☞ Annual rate of occurrence (ARO)-It refers to the number of times expected for an incident to occur in a year. If an incident occurred twice a month in the past year, the ARO is 24. Assuming nothing changes, it is likely that it will occur 24 times next year. Annual loss expectancy (ALE)-It is the expected loss for a year.

ALE is calculated by multiplying SLE with ARO. Because SLE is a given in a dollar value, ALE is also given in a dollar value. For example, if the SLE is \$1,000 and the ARO is 24, the ALE is \$24,000.

☞ $ALE = SLE * ARO$ Safeguard Value-This is the cost of a control. Controls are used to mitigate risk. For example, antivirus software of an average cost of \$50 for each computer. If there are 50 computers, the safeguard value is \$2,500. A, B, C: These are wrong formulas and are not

used in quantitative risk assessment.

58) Correct Answer: ABD

An enterprise's risk management capability maturity level is 3 when:

- ☞ Risk management is viewed as a business issue, and both the drawbacks and benefits of risk are recognized.
- ☞ There is a selected leader for risk management, engaged with the enterprise risk committee, across the enterprise.
- ☞ The business knows how IT fits in the enterprise risk universe and the risk portfolio view.
- ☞ Local tolerances drive the enterprise risk tolerance.
- ☞ Risk management activities are being aligned across the enterprise.
- ☞ Formal risk categories are identified and described in clear terms.
- ☞ Situations and scenarios are included in risk awareness training beyond specific policy and structures and promote a common language for communicating risk.
- ☞ Defined requirements exist for a centralized inventory of risk issues.
- ☞ Workflow tools are used to accelerate risk issues and track decisions.

Incorrect Answers:

C: Enterprise having risk management capability maturity level 5 requires continuous improvement of risk management skills, based on clearly defined personal and enterprise goals.

59) A

Business management is the business individuals with roles relating to managing a program. They are typically accountable for analyzing risks,

maintaining risk profile, and risk-aware decisions. Other than this, they are also responsible for managing risks, react to events, etc.

Incorrect Answers:

B: Business process owner is an individual responsible for identifying process requirements, approving process design and managing process performance. He/ she is responsible for analyzing risks, maintaining risk profile, and risk-aware decisions but is not accountable for them.

C: CIO is the most senior official of the enterprise who is accountable for IT advocacy; aligning IT and business strategies; and planning, resourcing and managing the delivery of IT services and information and the deployment of associated human resources. CIO has some responsibility analyzing risks, maintaining risk profile, and risk-aware decisions but is not accountable for them.

60) Correct Answer: C

Vulnerabilities represent characteristics of information resources that may be exploited by a threat. The given scenario describes such a situation; hence it is a vulnerability.

Incorrect Answers:

A: Probabilities represent the likelihood of the occurrence of a threat, and this scenario does not describe a probability.

B: Threats are circumstances or events with the potential to cause harm to information resources. This scenario does not describe a threat.

D: Impacts represent the outcome or result of a threat exploiting a vulnerability. The stem does not describe an impact.

61) Correct Answer: D

As regular audits can spot gaps in information security compliance, periodic

audits can ensure that outsourced service provider comply with the enterprise's information security policy.

Incorrect Answers:

A: Penetration testing can identify security vulnerability, but cannot ensure information compliance.

B: Service level monitoring can only identify operational issues in the enterprise's operational environment. It does not play any role in ensuring that outsourced service provider complies with the enterprise's information security policy.

C: Training can increase user awareness of the information security policy, but is less effective than periodic auditing.

62) Correct Answer: C

This is categorized as a business case to be made because the project cost is very large. The response to be implemented requires quite large investment.

Therefore, it comes under business case to be made.

Incorrect Answers:

A: It addresses costly risk response to a low risk. But here the response is less costly than that of business case to be made.

B: Quick win is very effective and efficient response that addresses medium to high risk. But in this the response does not require large investments.

D: This is not risk response prioritization option, instead it is a type of risk that happen with the several of the enterprise's business partners within a very short time frame.

63) Correct Answer: D

A review of the parameter settings will provide a good basis for comparison of the actual configuration to the security policy and will provide reliable audit evidence documentation.

Incorrect Answers:

A: While interviewing the firewall administrator may provide a good process overview, it does not reliably confirm that the firewall configuration complies with the enterprise's security policy.

B: While procedures may provide a good understanding of how the firewall is supposed to be managed, they do not reliably confirm that the firewall configuration complies with the enterprise's security policy.

C: While reviewing the device's log file for recent attacks may provide indirect evidence about the fact that logging is enabled, it does not reliably confirm that the firewall configuration complies with the enterprise's security policy.

64) Correct Answer: C

Incorrect Answers:

A, B, D: Productivity, quality and customer service are used for evaluating critical service factor of any particular project.

65) Correct Answer: C

The risk management plan details how risk management processes will be implemented, monitored, and controlled throughout the life of the project. The risk management plan does not include responses to risks or triggers. Responses to risks are documented in the risk register as part of the Plan Risk Responses process.

Incorrect Answers:

A, B, D: These all statements are true for risk management plan. The risk management plan details how risk management processes will be implemented, monitored, and controlled throughout the life of the project. It includes thresholds, scoring and interpretation methods, responsible parties, and budgets. It also acts as input to all the remaining risk-planning processes.

66) Correct Answer: C

Decision tree analysis is a risk analysis tool that can help the project manager in determining the best risk response. The tool can be used to measure probability, impact, and risk exposure and how the selected risk response can affect the probability and/or impact of the selected risk event. It helps to form a balanced image of the risks and opportunities connected with each possible course of action. This makes them mostly useful for choosing between different strategies, projects, or investment opportunities particularly when the resources are limited. A decision tree is a decision support tool that uses a tree-like graph or model of decisions and their possible consequences, including chance event outcomes, resource costs, and utility.

Incorrect Answers:

A: Project network diagrams help the project manager and stakeholders visualize the flow of the project work, but they are not used as a part of risk response planning.

B: Cause-and-effect analysis is used for exposing risk factors and not an effective one in risk response planning.

This analysis involves the use of predictive or diagnostic analytical tool for exploring the root causes or factors that contribute to positive or negative effects or outcomes.

D: Delphi technique is used for risk analysis, i.e., for identifying the most probable risks. Delphi is a group of experts who used to rate independently the business risk of an organization. Each expert analyzes the risk

independently and then prioritizes the risk, and the result is combined into a consensus.

67) Correct Answer: B

0 nonexistent: An enterprise's risk management capability maturity level is 0 when:

- ☞ The enterprise does not recognize the need to consider the risk management or the business impact from IT risk.
- ☞ Decisions involving risk lack credible information.
- ☞ Awareness of external requirements for risk management and integration with enterprise risk management (ERM) do not exists.

Incorrect Answers:

A, C, D: These all are much higher levels of the risk management capability maturity model and in all these enterprises do take decisions considering the risk credential information. Moreover, in these levels enterprise is aware of external requirements for risk management and integrate with ERM.

68) Correct Answer: A

Data owners are responsible for assigning user entitlement changes and approving access to the systems for which they are responsible.

Incorrect Answers:

B, C, D: Data owners are not responsible for intrusion detection, platform security or antivirus controls.

These are the responsibilities of data custodians.

69) Correct Answer: B

An acceptable use policy is a set of rules applied by the owner/manager of a network, website or large computer system that restrict the ways in which the network site or system may be used. Acceptable Use Policies are an integral part of the framework of information security policies.

Incorrect Answers:

A, C: These two policies are not related to Information system security.

D: Privacy policy is a statement or a legal document (privacy law) that discloses some or all of the ways a party gathers, uses, discloses and manages a customer or client's data.

70) Correct Answer: A

Risk mitigation implies a reduction in the probability and/or impact of an adverse risk event to be within acceptable threshold limits. Taking early actions to reduce the probability and/or impact of a risk occurring on the project is often more effective than trying to repair the damage after the risk has occurred.

Incorrect Answers:

B: Avoidance changes the project plan to avoid the risk altogether.

C: Transference requires shifting some or all of the negative impacts of a threat, along with the ownership of the response, to a third party. Transferring the risk simply gives another party the responsibility for its management-it does not eliminate it.

Transferring the liability for a risk is most effective in dealing with financial risk exposure. Risk transference nearly always involves payment of a risk premium to the party taking on the risk.

D: Enhancing is actually a positive risk response. This strategy is used to

increase the probability and/or the positive impact of an opportunity. Identifying and maximizing the key drivers of these positive-impact risks may increase the probability of their occurrence.

71) Correct Answer: B

The plan risk response project management process aims to reduce the threats to the project objectives and to increase opportunities. It follows the perform qualitative risk analysis process and perform quantitative risk analysis process. Plan risk response process includes the risk response owner to take the job for each agreed-to and funded risk response. This process addresses the risks by their priorities, schedules the project management plan as required, and inserts resources and activities into the budget. The inputs to the plan risk response process are as follows:

☞ Risk register

Risk management plan -

Incorrect Answers:

A: Monitor and Control Risk is the process of implementing risk response plans, tracking identified risks, monitoring residual risk, identifying new risks, and evaluating risk process effectiveness throughout the project. It can involve choosing alternative strategies, executing a contingency or fallback plan, taking corrective action, and modifying the project management plan.

C: Identify Risks is the process of determining which risks may affect the project. It also documents risks' characteristics. The Identify Risks process is part of the

Project Risk Management knowledge area. As new risks may evolve or become known as the project progresses through its life cycle, Identify Risks is an iterative process. The process should involve the project team so that they can develop and maintain a sense of ownership and responsibility for the risks and associated risk response actions. Risk Register is the only output of this process.

D: Qualitative analysis is the definition of risk factors in terms of high/medium/low or a numeric scale (1 to 10). Hence it determines the nature of risk on a relative scale.

Some of the qualitative methods of risk analysis are:

☞ Scenario analysis- This is a forward-looking process that can reflect risk for a given point in time.

☞ Risk Control Self -assessment (RCSA) - RCSA is used by enterprises (like banks) for the identification and evaluation of operational risk exposure. It is a logical first step and assumes that business owners and managers are closest to the issues and have the most expertise as to the source of the risk. RCSA is a constructive process in compelling business owners to contemplate, and then explain, the issues at hand with the added benefit of increasing their accountability.

72) Correct Answer: D

Among the given choices only Acceptance response is used for negative risk events. Risk acceptance means that no action is taken relative to a particular risk; loss is accepted if it occurs. If an enterprise adopts a risk acceptance, it should carefully consider who can accept the risk. Risk should be accepted only by senior management in relationship with senior management and the board. There are two alternatives to the acceptance strategy, passive and active.

☞ Passive acceptance means that enterprise has made no plan to avoid or mitigate the risk but willing to accept the consequences of the risk.

Active acceptance is the second strategy and might include developing contingency plans and reserves to deal with risks.

Incorrect Answers:

A, B, C: These all are used to deal with opportunities or positive risks, and not with negative risks.

73) Correct Answer: D

Probability that an actual return on an investment will be lower than the investor's expectations is termed as investment risk or expense risk. All investments have some level of risk associated with it due to the unpredictability of the market's direction. This includes consideration of the overall IT investment portfolio.

Incorrect Answers:

A: The risk that data cannot be relied on because they are unauthorized, incomplete or inaccurate is termed as integrity risks.

B: The risk of IT projects failing to meet objectives due to lack of accountability and commitment is referring to as project risk ownership.

C: The risk associated with not receiving the right information to the right people (or process or systems) at the right time to allow the right action to be taken is termed as relevance risk.

74) Correct Answer: AB

Creating a scenario requires determination of the value of an asset or a business process at risk and the potential threats and vulnerabilities that could cause loss.

The risk scenario should be assessed for relevance and realism, and then entered into the risk register if found to be relevant.

In practice following steps are involved in risk scenario development:

- ☞ First determine manageable set of scenarios, which include:
- ☞ Frequently occurring scenarios in the industry or product area.
- ☞ Scenarios representing threat sources that are increasing in count or severity level.

- ☞ Scenarios involving legal and regulatory requirements applicable to the business.
- ☞ After determining manageable risk scenarios, perform a validation against the business objectives of the entity.
- ☞ Based on this validation, refine the selected scenarios and then detail them to a level in line with the criticality of the entity.
- ☞ Lower down the number of scenarios to a manageable set. Manageable does not signify a fixed number, but should be in line with the overall importance and criticality of the unit.
- ☞ Risk factors kept in a register so that they can be reevaluated in the next iteration and included for detailed analysis if they have become relevant at that time.
- ☞ Risk factors kept in a register so that they can be reevaluated in the next iteration and included for detailed analysis if they have become relevant at that time.
- ☞ Include an unspecified event in the scenarios, that is, address an incident not covered by other scenarios.

Incorrect Answers:

C, D: Determination of actors and threat type are not the primary requirements for developing risk scenarios, but are the components that are determined during risk scenario development.

75) Correct Answer: ABD

Chief Risk Officer is the executive-level manager in an organization. They provide corporate, guidance, governance, and oversight over the enterprise's risk management activities. The main priority for the CRO is to ensure that the organization is in full compliance with applicable regulations. They may also deal with areas regarding insurance, internal auditing, corporate investigations, fraud, and information security.

CRO's responsibilities include:

- ☞ Managing the risk assessment process
- ☞ Implementation of corrective actions
- ☞ Communicate risk management issues
- ☞ Supporting the risk management functions

76) Correct Answer: A

The contract change control system is part of the project's change control system. It addresses changes with the vendor that may affect the project contract.

Change control system, a part of the configuration management system, is a collection of formal documented procedures that define how project deliverables and documentation will be controlled, changed, and approved.

Incorrect Answers:

B: The scope may change because of the stakeholder change request.

Vendor's relationship to the project, hence this choice is not the best answer.

C: The cost change control system manages changes to costs in the project.

D: There is no indication that the change could affect the project schedule.

77) Correct Answer: C

If the costs of specific controls or countermeasures (control overhead) exceed the benefits of mitigating a given risk the enterprise may choose to accept the risk rather than incur the cost of mitigation. This is done according to the principle of proportionality described in:

- ☞ Generally accepted security systems principles (GASSP)

☞ Generally accepted information security principles (GAISP)

Incorrect Answers:

A: When the cost of specific controls exceeds the benefits of mitigating a given risk, then controls are not applied, rather risk is being accepted.

B: As the cost of control exceeds the benefits of mitigating a given risk, hence no control should be applied.

Corrective control is a type of control and hence it should not be adopted.

D: The risk is being exploited when there is an opportunity, i.e., the risk is positive. But here in this case, negative risk exists as it needs mitigation. So, exploitation cannot be done.

78) Correct Answer: ABD

Probability identifies the chances that a particular event will happen under certain circumstances.

The variables provided are based on information gathered in real life. For situations with large numbers, a smaller set of participants are identified to represent the larger population. This represents a sample of the population. The points are mapped to identify their distribution.

Normal distribution refers to the theoretical plotting of points against the mathematical mean.

The result of these activities provides a reasonable predictability for the mortality of the subject.

Incorrect Answers:

C: Impact is used to identify the magnitude of identified risks. The risk leads to some type of loss. However, instead of quantifying the loss as a dollar value, an impact assessment could use words such as Low, Medium, or High.

Hence it is not mathematical.

79) Correct Answer: A

Risk transfer means that impact of risk is reduced by transferring or otherwise sharing a portion of the risk with an external organization or another internal entity.

Transfer of risk can occur in many forms but is most effective when dealing with financial risks. Insurance is one form of risk transfer. Hence when Harry hires a professional vendor to manage that risk, the risk event does not go away but the responsibility for the event is transferred to the vendor.

Incorrect Answers:

B: Risk acceptance means that no action is taken relative to a particular risk; loss is accepted if it occurs. Here Harry is not accepting this risk event; he does not want anyone of his team to become injured so he's transferring the event to professional vendor.

C: Mitigation are actions that Harry's project team could take to reduce the probability and/or impact of a risk event.

D: Avoidance removes the risk event entirely either by adding additional steps to avoid the event or reducing the project scope.

80) Correct Answer: D

The project team members should be involved in the risk identification so that they will develop a sense of ownership and responsibility for the risk events and the associated risk responses.

Identify Risks is the process of determining which risks may affect the project. It also documents risks' characteristics. The Identify Risks process is part of the

Project Risk Management knowledge area. As new risks may evolve or

become known as the project progresses through its life cycle, Identify Risks is an iterative process. The process should involve the project team so that they can develop and maintain a sense of ownership and responsibility for the risks and associated risk response actions. Risk Register is the only output of this process.

Incorrect Answers:

A, B, C: These are not the valid answers for this question.

81) Correct Answer: BCD

It is important to first understand the risk to be monitored, prepare a detailed plan and define the project's scope for monitoring risk. In the case of a monitoring project, this step should involve process owners, data owners, system custodians and other process stakeholders.

Incorrect Answers:

A: Data regarding stakeholders of the project is not required in any phase of risk monitoring.

82) Correct Answer: A

Risk transfer is the practice of passing risk from one entity to another entity. In other words, if a company is covered under a liability insurance policy providing various liability coverage for information security risks, including any physical damage of assets, hacking attacks, etc., it means it has transferred its security risks to the insurance company.

Incorrect Answers:

B: Risk acceptance is the practice of accepting certain risk(s), typically based

on a business decision that may also weigh the cost versus the benefit of dealing with the risk in another way.

C: Risk avoidance is the practice of not performing an activity that could carry risk. Avoidance may seem the answer to all risks, but avoiding risks also means losing out on the potential gain that accepting (retaining) the risk may have allowed.

D: Risk mitigation is the practice of reducing the severity of the loss or the likelihood of the loss from occurring.

83) Correct Answer: D

By focusing on the high-priority of risk events through qualitative risk analysis you can improve the project's performance.

Qualitative analysis is the definition of risk factors in terms of high/medium/low or a numeric scale (1 to 10). Hence it determines the nature of risk on a relative scale.

Some of the qualitative methods of risk analysis are:

☞ Scenario analysis- This is a forward-looking process that can reflect risk for a given point in time.

☞ Risk Control Self -assessment (RCSA) - RCSA is used by enterprises (like banks) for the identification and evaluation of operational risk exposure. It is a logical first step and assumes that business owners and managers are closest to the issues and have the most expertise as to the source of the risk. RCSA is a constructive process in compelling business owners to contemplate, and then explain, the issues at hand with the added benefit of increasing their accountability.

Incorrect Answers:

A: Subject matter experts can help the qualitative risk assessment, but by focusing on high-priority risks the project's performance can improve by addressing these risk events.

B: Stakeholders should be involved throughout the project as situations within the project demand their input to risk identification and analysis.

C: Qualitative analysis does use a fast approach of analyzing project risks, but it's not the best answer for this.

84) Correct Answer: C

According to the PMBOK, a project risk is always in the future. If the risk event has already happened, then it is an issue, not a risk.

Incorrect Answers:

A: You can identify risks before they occur and not after their occurrence.

B: Risks can only happen in the future.

D: Triggers are warning signs and conditions of risk events, but this answer isn't the best choice for this question.

85) Correct Answer: C

Risk indicators are metrics used to indicate risk thresholds, i.e., it gives indication when a risk level is approaching a high or unacceptable level of risk. The main objective of a risk indicator is to ensure tracking and reporting mechanisms that alert staff about the potential risks.

Incorrect Answers:

A: A risk register is an inventory of risks and exposure associated with those risks. Risks are commonly found in project management practices, and provide information to identify, analyze, and manage risks. Typically, a risk register contains:

☞ A description of the risk

- ☞ The impact should this event actually occur
- ☞ The probability of its occurrence
- ☞ Risk Score (the multiplication of Probability and Impact)
- ☞ A summary of the planned response should the event occur
- ☞ A summary of the mitigation (the actions taken in advance to reduce the probability and/or impact of the event)
- ☞ Ranking of risks by Risk Score so as to highlight the highest priority risks to all involved.

D: Return on Investment (ROI) is a performance measure used to evaluate the efficiency of an investment or to compare the efficiency of a number of different investments. To calculate ROI, the benefit (return) of an investment is divided by the cost of the investment; the result is expressed as a percentage or a ratio.

The return-on-investment formula:

$$\text{ROI} = (\text{Gain from investment} - \text{Cost of investment}) / \text{Cost of investment}$$

In the above formula "gains from investment", refers to the proceeds obtained from selling the investment of interest.

86) Correct Answer: C

The Communications Management Plan defines, in regard to risk management, who will be available to share information on risks and responses throughout the project.

The Communications Management Plan aims to define the communication necessities for the project and how the information will be circulated. The

Communications Management Plan sets the communication structure for the project. This structure provides guidance for communication throughout the project's life and is updated as communication needs change. The Communication Managements Plan identifies and defines the roles of persons concerned with the project. It includes a matrix known as the communication

matrix to map the communication requirements of the project.

Incorrect Answers:

A: The Risk Management Plan defines risk identification, analysis, response, and monitoring.

B: The stakeholder management strategy does not address risk communications.

D: The Resource Management Plan does not define risk communications.

87) Correct Answer: A

The Delphi technique uses rounds of anonymous surveys to build consensus on project risks. Delphi is a technique to identify potential risk. In this technique, the responses are gathered via a question and their inputs are organized according to their contents. The collected responses are sent back to these experts for further input, addition, and comments. The final list of risks in the project is prepared after that. The participants in this technique are anonymous and therefore it helps prevent a person from unduly influencing the others in the group. The Delphi technique helps in reaching the consensus quickly.

Incorrect Answers:

B: Root cause analysis is not an anonymous approach to risk identification.

C: Isolated pilot groups is not a valid risk identification activity.

D: SWOT analysis evaluates the strengths, weaknesses, opportunities, and threats of the project.

88) Correct Answer: A

Vulnerability is a weakness or lack of safeguard that can be exploited by a

threat, thus causing harm to the information systems or networks. It can exist in hardware, operating systems, firmware, applications, and configuration files. Hence lack of adequate controls represents vulnerability and would ultimately cause threat to the enterprise.

Incorrect Answers:

B: Threat is the potential cause of unwanted incident.

C: Assets are economic resources that are tangible or intangible, and is capable of being owned or controlled to produce value.

D: Impact is the measure of the financial loss that the threat event may have.

89) Correct Answer: B

The risk matrix is not included as part of the risk register updates. There are seven things that can be updated in the risk register as a result of qualitative risk analysis: relating ranking of project risks, risks grouped by categories, causes of risks, list of near-term risks, risks requiring additional analysis, watchlist of low- priority risks, trends in qualitative risk analysis.

Incorrect Answers:

A: Trends in qualitative risk analysis are part of the risk register updates.

C: Risks grouped by categories are part of the risk register updates.

D: Watchlist of low-priority risks is part of the risk register updates.

90) Correct Answer: D

Systemic risks are those risks that happen with an important business partner and affect a large group of enterprises within an area or industry. An example would be a nationwide air traffic control system that goes down for an extended period of time (six hours), which affects air traffic on a very large

scale.

Incorrect Answers:

A: Contagious risks are those risk events that happen with several of the enterprise's business partners within a very short time frame.

B, C: Their scopes do not limit to the important or general enterprise's business partners. These risks can occur with both.

Operational risks are those risks that are associated with the day-to-day operations of the enterprise. It is the risk of loss resulting from inadequate or failed internal processes, people and systems, or from external events.

Reporting risks are caused due to wrong reporting which leads to bad decision. This bad decision due to wrong report hence causes a risk on the functionality of the organization.

91) Correct Answer: B

Risk rating rules define how to prioritize risks after the related probability and impact values are calculated. These are generally included in the organizational process assets and are refined for individual projects.

Incorrect Answers:

A: Affinity Diagram is a method of group creativity technique to collect requirements which allows large numbers of ideas to be sorted into groups for review and analysis. This is generally used in Scope Management and not applicable to this option.

C: A Project Network diagram shows the sequencing and linkage between various project tasks and is not applicable to this question

D: Risk categories are an output of the Perform Qualitative Risk Analysis process and not a tool to complete the process.

92) Correct Answer: B

Whenever the customer or key stakeholder asks for a change in the existing plan, you should ask him/her to submit a formal change request. Change requests may modify project policies or procedures, project scope, project cost or budget, project schedule, or project quality.

Incorrect Answers:

A, C, D: The first action required is to create a formal change request, if a change is requested in the project.

93) Correct Answer: A

The Certainty equivalent value is the expected guaranteed value of taking a risk. It is derived by the uncertainty of the situation and the potential value of the situation's outcome.

Incorrect Answers:

B: The risk premium is the difference between the larger expected value of the risk and the smaller certainty equivalent value.

C, D: These are not valid answers.

94) Correct Answer: B

Triggers are warning signs of an upcoming risk event. Here delay in delivery signifies that there may be a risk event like delay in completion of project. Hence it is referred to as a trigger.

Incorrect Answers:

A: Residual risk is the risk that remains after applying controls. But here in

this scenario, risk event has not occurred yet.

C: A contingency plan is a plan devised for a specific situation when things go wrong. Contingency plans are often devised by governments or businesses who want to be prepared for anything that could happen. Here there are no such plans.

D: Secondary risks are risks that come about as a result of implementing a risk response. But here in this scenario, risk event has not occurred yet.

95) Correct Answer: B

Enterprise environmental factor is not an input to the quantitative risk analysis process. The five inputs to the perform quantitative risk analysis process are: risk register, risk management plan, cost management plan, schedule management plan, and organizational process assets.

Incorrect Answers:

A, C, D: These are the valid inputs to the perform quantitative risk analysis process.

96) Correct Answer: B

The low probability and low impact risks should be added to a watchlist for future monitoring.

Incorrect Answers:

A: The risk response for these events may be to accept them, but the best answer is to first add them to a watchlist.

C: Risks are not dismissed; they are at least added to a watchlist for monitoring.

D: While the risks may eventually be added to the register, the best answer is

to first add them to the watchlist for monitoring.

97) Correct Answer: C

All identified risk events should be entered into the risk register.

A risk register is an inventory of risks and exposure associated with those risks. Risks are commonly found in project management practices, and provide information to identify, analyze, and manage risks. Typically, a risk register contains:

- ☞ A description of the risk
- ☞ The impact should this event actually occur
- ☞ The probability of its occurrence
- ☞ Risk Score (the multiplication of Probability and Impact)
- ☞ A summary of the planned response should the event occur
- ☞ A summary of the mitigation (the actions taken in advance to reduce the probability and/or impact of the event)
- ☞ Ranking of risks by Risk Score so as to highlight the highest priority risks to all involved.

Incorrect Answers:

A: Before the risk events are analyzed they should be documented in the risk register.

B: The risks should first be documented and analyzed.

D: These risks should first be identified, documented, passed through qualitative risk analysis and then it should be determined if they should pass through the quantitative risk analysis process.

98) Correct Answer: A

Each business process involves inherent risk. Not engaging in any activity avoids the inherent risk associated with the activity. Hence this demonstrates risk avoidance.

Incorrect Answers:

B: Risk treatment means that action is taken to reduce the frequency and impact of a risk.

C: Acceptance means that no action is taken relative to a particular risk, and loss is accepted when/if it occurs. This is different from being ignorant of risk; accepting risk assumes that the risk is known, i.e., an informed decision has been made by management to accept it as such.

D: Risk transfer/sharing means reducing either risk frequency or impact by transferring or otherwise sharing a portion of the risk. Common techniques include insurance and outsourcing. These techniques do not relieve an enterprise of a risk, but can involve the skills of another party in managing the risk and reducing the financial consequence if an adverse event occurs.

99) Correct Answer: ABD

The risk components defined by the COSO ERM are internal environment, objective settings, event identification, risk assessment, risk response, control objectives, information and communication, and monitoring.

Incorrect Answers:

C: Business continuity is not considered as risk component within the ERM framework.

100) Correct Answer: C

The outcome of quantitative analysis can create a listing of prioritized risks that should be updated in the risk register. The project team will create and

update the risk register with four key components:

- ☞ probabilistic analysis of the project
- ☞ probability of achieving time and cost objectives
- ☞ list of quantified risks
- ☞ trends in quantitative risk analysis

Incorrect Answers:

A, B, D: These subjects are not updated in the risk register as a result of quantitative risk analysis.

101) Correct Answer: C

There is only one tool and technique available for Fred to plan risk management: planning meetings and analysis. Planning Meeting and Analysis is a tool and technique in the Plan Risk Management process. Planning meetings are organized by the project teams to develop the risk management plan. Attendees at these meetings include the following:

- ☞ Project manager
- ☞ Selected project team members
- ☞ Stakeholders
- ☞ Anybody in the organization with the task to manage risk planning

Sophisticated plans for conducting the risk management activities are defined in these meetings, responsibilities related to risk management are assigned, and risk contingency reserve application approaches are established and reviewed.

Incorrect Answers:

A, B, D: These are not plan risk management tools and techniques.

102) Correct Answer: C

There is an increased risk without a policy defining who has the responsibility for granting access to specific data or systems, as one could

gain system access without a justified business needs. There is better chance that business objectives will be properly supported when there is appropriate ownership.

Incorrect Answers:

A, B, D: These risks are not such significant as compared to unauthorized access.

103) Correct Answer: B

Secondary risks are the risks that come about as a result of implementing a risk response. This new risk event must be recorded, analyzed, and planned for management.

Incorrect Answers:

A: A residual risk event is similar to a secondary risk, but is often small in probability and impact, so it may just be accepted.

C: Infinitive risk is not a valid project management term.

D: Populated risk event is not a valid project management term.

104) Correct Answer: B

Risk register update is the only output of the choices presented for the qualitative risk analysis process. The four inputs for the qualitative risk analysis process are the risk register, risk management plan, project scope statement, and organizational process assets. The output of perform qualitative risk analysis process is Risk

Register Updates. Risk register is updated with the information from perform qualitative risk analysis and the updated risk register is included in the project documents. Updates include the following important elements:

- ☞ Relative ranking or priority list of project risks
- ☞ Risks grouped by categories
- ☞ Causes of risk or project areas requiring particular attention
- ☞ List of risks requiring response in the near-term
- ☞ List of risks for additional analysis and response
- ☞ Watchlist of low priority risks
- ☞ Trends in qualitative risk analysis results

Incorrect Answers:

A, C, D: These are not the valid outputs for the qualitative risk analysis process.

105) Correct Answer: A

Inspection of FISMA is required to be done annually. Each year, agencies must have an independent evaluation of their program. The objective is to determine the effectiveness of the program. These evaluations include:

- ☞ Testing for effectiveness: Policies, procedures, and practices are to be tested. This evaluation does not test every policy, procedure, and practice. Instead, a representative sample is tested.
- ☞ An assessment or report: This report identifies the agency's compliance as well as lists compliance with FISMA. It also lists compliance with other standards and guidelines.

Incorrect Answers:

B, C, D: Auditing of compliance by external organization is done annually, not quarterly or every three years.

106) Correct Answer: CD

The foremost root cause of project risk is:

- ☞ A lack of discipline in managing the software development process
- ☞ Selection of a project methodology that is unsuitable to the system being developed

Incorrect Answers:

A: The risk associated with new system is not meeting the user business needs is business risks, not project risk.

B: This is not direct reason of project risk.

107) Correct Answer: C

The manage stakeholder expectations process can create change requests for the project, which can cause new risk events to enter into the project.

Change requests are requests to expand or reduce the project scope, modify policies, processes, plans, or procedures, modify costs or budgets or revise schedules. These requests for a change can be direct or indirect, externally or internally initiated, and legally or contractually imposed or optional. A Project

Manager needs to ensure that only formally documented requested changes are processed and only approved change requests are implemented.

Incorrect Answers:

A: The project management plan updates do not create new risks.

B: The organizational process assets updates do not create new risks.

D: The project document updates do not create new risks.

108) Correct Answer: C

A control or countermeasure which does not overlap in its performance with another control or countermeasure is considered as distinct. Hence the separation of controls in the production environment rather than the separation in the design and implementation of the risk refers to distinct.

Incorrect Answers:

A: Trusted source refers to the commitment of the people designing, implementing, and maintenance of the control towards the security policy.

B: Secure controls refers to the activities ability to protect from exploitation or attack.

D: The separation in design, implementation, and maintenance of controls or countermeasures are refer to as independent. Hence this answer is not valid.

109) Correct Answer: D

By establishing definitions for the level of probability and impact a project manager can reduce the influence of bias.

Incorrect Answers:

A: This is not a valid statement for reducing bias in the qualitative risk analysis.

B: Positive and negative stakeholders are identified based on their position towards the project goals and objectives, not necessarily risks.

C: Root cause analysis is a good exercise, but it would not determine risk bias.

110) Correct Answer: A

When a new regulation for safeguarding information processed by a specific type of transaction is being identified by the IT manager, then the immediate step would be to understand the impact and requirements of this new regulation. This includes assessing how the enterprise will comply with the regulation and to what extent the existing control structure supports the compliance process. After that manager should then assess any existing gaps.

Incorrect Answers:

B, C, D: These choices are appropriate as well as important, but are subsequent steps after understanding and gap assessment.

111) Correct Answer: C

When the risk level is less than risk tolerance level of the enterprise than no action is taken against that, because the cost of mitigation will increase over its benefits.

Incorrect Answers:

A: This is not a valid answer, as no response is being applied to such low risk level.

B: Risk register is updates after applying response, and as no response is applied to such low risk level; hence no updating is done.

D: This is not a valid answer, as no response is being applied to such low risk level.

112) Correct Answer: D

Profitability operational risks focus on the financial risks which encompass providing a quality product that is cost-effective in production. It ensures that the provision of a quality product is not overshadowed by the production costs of that product.

Incorrect Answers:

A: Information security means protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, perusal, inspection, recording or destruction. Information security risks are the risks that are associated with the protection of these information and information systems.

B: These risks do not ensure that the provision of a quality product is not overshadowed by the production costs of that product.

C: Project activity risks are not associated with provision of a quality product or the production costs of that product.

113) Correct Answer: B

A quantitative risk assessment quantifies risk in terms of numbers such as dollar values. This involves gathering data and then entering it into standard formulas.

The results can help in identifying the priority of risks. These results are also used to determine the effectiveness of controls. Some of the terms associated with quantitative risk assessments are:

☞ Single loss expectancy (SLE)-It refers to the total loss expected from a single incident. This incident can occur when vulnerability is being exploited by threat.

The loss is expressed as a dollar value such as \$1,000. It includes the value of data, software, and hardware.

$SLE = \text{Asset value} * \text{Exposure factor}$

☞ Annual rate of occurrence (ARO)-It refers to the number of times expected for an incident to occur in a year. If an incident occurred twice a month in the past year, the ARO is 24. Assuming nothing changes, it is likely that it will occur 24 times next year.

☞ Annual loss expectancy (ALE)-It is the expected loss for a year. ALE is calculated by multiplying SLE with ARO. Because SLE is given in a dollar value, ALE is also given in a dollar value. For example, if the SLE is \$1,000 and the ARO is 24, the ALE is \$24,000. $ALE = SLE * ARO$

☞ Safeguard Value-This is the cost of a control. Controls are used to mitigate risk. For example, antivirus software of an average cost of \$50 for each computer. If there are 50 computers, the safeguard value is \$2,500.

Incorrect Answers:

A: The first thing we must do in risk management is to identify the areas of the project where the risks can occur. This is termed as risk identification. Listing all the possible risks is proved to be very productive for the enterprise as we can cure them before it can occur. In risk identification both threats and opportunities are considered, as both carry some level of risk with them.

C: Unlike the quantitative risk assessment, qualitative risk assessment does not assign dollar values. Rather, it determines risk's level based on the probability and impact of a risk. These values are determined by gathering the opinions of experts.

☞ Probability- establishing the likelihood of occurrence and reoccurrence of specific risks, independently, and combined. The risk occurs when a threat exploits vulnerability. Scaling is done to define the probability that a risk will occur. The scale can be based on word values such as Low, Medium, or High. Percentage can also be assigned to these words, like 10% to low and 90% to high.

☞ Impact- Impact is used to identify the magnitude of identified risks. The risk leads to some type of loss. However, instead of quantifying the loss as a dollar value, an impact assessment could use words such as Low, Medium, or High. Impact is expressed as a relative value. For example, low could be 10, medium could be 50, and high could be 100.

Risk level = Probability*Impact -

D: This is the process of implementing risk response plans, tracking identified risks, monitoring residual risks, identifying new risks, and evaluating risk process effectiveness through the project.

114) Correct Answer: D

Risk communication is the process of exchanging information and views about risks among stakeholders, such as groups, individuals, and institutions. Risk communication is mostly concerned with the nature of risk or expressing concerns, views, or reactions to risk managers or institutional bodies for risk management. The key plan to consider and communicate risk is to categorize and impose priorities, and acquire suitable measures to reduce risks. It is important throughout any crisis to put across multifaceted information in a simple and clear manner. Risk communication helps in switching or allocating the information concerning risk among the decision-maker and the stakeholders. Risk communication can be explained more clearly with the help of the following definitions:

- ☞ It defines the issue of what a group does, not just what it says.
- ☞ It must take into account the valuable element in user's perceptions of risk.
- ☞ It will be more valuable if it is thought of as conversation, not instruction.

Risk communication is a fundamental and continuing element of the risk analysis exercise, and the involvement of the stakeholder group is from the beginning. It makes the stakeholders conscious of the process at each phase of the risk assessment. It helps to guarantee that the restrictions, outcomes, consequence, logic, and risk assessment are undoubtedly understood by all the stakeholders.

Incorrect Answers:

A: Risk governance is a systemic approach to decision making processes associated to natural and technological risks. It is based on the principles of cooperation, participation, mitigation and sustainability, and is adopted to

achieve more effective risk management. It seeks to reduce risk exposure and vulnerability by filling gaps in risk policy, in order to avoid or reduce human and economic costs caused by disasters.

Risk governance is a continuous life cycle that requires regular reporting and ongoing review. The risk governance function must oversee the operations of the risk management team.

B: The International Risk Governance Council (IRGC) is a self-governing organization whose principle is to facilitate the understanding and managing the rising overall risks that have impacts on the economy and society, human health and safety, the environment at large. IRGC's effort is to build and develop concepts of risk governance, predict main risk issues and present risk governance policy recommendations for the chief decision makers. IRGC mainly emphasizes on rising, universal risks for which governance deficits exist.

Its goal is to present recommendations for how policy makers can correct them. IRGC models at constructing strong, integrative inter-disciplinary governance models for up-coming and existing risks.

C: Risk response is a process of deciding what measures should be taken to reduce threats and take advantage of the opportunities discovered during the risk analysis processes. This process also includes assigning departments or individual staff members the responsibility of carrying out the risk response plans and these folks are known as risk owners.

The prioritization of the risk responses and development of the risk response plan is based on following parameters:

- ☞ Cost of the response to reduce risk within tolerance levels
- ☞ Importance of the risk
- ☞ Capability to implement the response
- ☞ Effectiveness and efficiency of the response

Risk prioritization strategy is used to create a risk response plan and implementation schedule because all risk cannot be addressed at the same time. It may take considerable investment of time and resources to address all

the risk identified in the risk analysis process. Risk with a greater likelihood and impact on the enterprise will be prioritized above other risk that is considered less likely or has less impact.

115) Correct Answer: ABD

The International Organization for Standardization (ISO) identifies the following principles of risk management. Risk management should:

- ☞ create value
 - ☞ be an integral part of organizational processes
 - ☞ be part of decision making
 - ☞ explicitly address uncertainty
 - ☞ be systematic and structured
 - ☞ be based on the best available information
 - ☞ be tailored
 - ☞ take into account human factors
 - ☞ be transparent and inclusive
 - ☞ be dynamic, iterative, and responsive to change
- be capable of continual improvement and enhancement

116) Correct Answer: B

Sustainability ensures that the control continues to function as expressed over the time and adopts as changes or new elements are introduced to the environment.

Incorrect Answers:

A: Reliability of control ensures that it will serve its purpose under multiple

circumstances.

C: Consistent characteristic of the control tells whether the control can be applied in the same manner across the organization.

D: A control or countermeasure which does not overlap in its performance with another control or countermeasure is considered as distinct. Hence the separation of controls in the production environment rather than the separation in the design and implementation of the risk refers to distinct.

117) Correct Answer: ABC

The various tools & techniques used in the identify risk process are as follows:

- ☞ Documentation reviews
- ☞ Information gathering technique
- ☞ Checklist analysis
- ☞ Assumption analysis
- ☞ Diagramming techniques
- ☞ SWOT analysis
- ☞ Expert judgment

118) Correct Answer: B

The controls within the schedule management plan can shape how quantitative risk analysis will be performed on the schedule.

Schedule management plan also describes how the schedule contingencies will be reported and assessed.

Incorrect Answers:

A: When risks are likely to happen is important, but it is not the best answer for this question

C: This is not a valid answer for this question throughout the project, but it is not scheduled during the quantitative risk analysis process.

D: Risks may affect the project schedule, but this is not the best answer for the question.

119) Correct Answer: D

Preventative controls are the controls that detect the problem before it occurs. They attempt to predict potential problems and make adjustments to prevent those problems to occur in near future. This prediction is being made by monitoring both the system's operations and its inputs.

The keyword is "before it can occur". So the answer is D.

Incorrect Answers:

A: Deterrent controls are similar to the preventative controls, but they diminish or reverse the attraction of the environment to prevent risk from occurring instead of making adjustments to the environment.

B: Detective controls simply detect and report on the occurrence of a problems. They identify specific symptoms to potential problems.

C: Compensation controls ensure that normal business operations continue by applying appropriate resource.

120) Correct Answer: ACD

The internal environment for risk management is the foundational level of the COSO ERM framework, which describes the philosophical basics of managing risks within the implementing enterprise. The different aspects of the internal environment include the enterprise's:

☞ Philosophy on risk management

☞ Risk appetite

- ☞ Attitudes of Board of Directors
- ☞ Integrity and ethical values
- ☞ Commitment to competence
- ☞ Organizational structure
- ☞ Authority and responsibility
- ☞ Human resource standards

121) Correct Answer: D

Catastrophic risk causes critical financial losses that have the possibility of bankruptcy.

Incorrect Answers:

A: Marginal risk causes financial loss in a single line of business and a reduced return on IT investment.

B: It causes minimal impact on a single line of business affecting their ability to deliver services or products.

C: Critical risk causes serious financial losses in more than one line of business with a loss in productivity.

122) Correct Answer: C

Watch-list contains risks with low rating of probability and impact. This list is useful for future monitoring of low risk factors.

Incorrect Answers:

A, B: No such documents as risk alarm and observation list is prepared during risk identification process.

D: Risk register is a document that contains the results of the qualitative risk analysis, quantitative risk analysis, and risk response planning. Description, category, cause, probability of occurring, impact on objectives, proposed responses, owner, and the current status of all identified risks are put in the risk register.

123) Correct Answer: B

Quantitative risk analysis is generally more complex and thus is costlier than qualitative risk analysis.

Incorrect Answers:

A: Neither of the two risk analysis methods is fully objective. Qualitative method subjectively assigns high, medium and low frequency and impact categories to a specific risk, whereas quantitative method subjectivity expressed in mathematical "weights".

C: To be effective, both processes require personnel who have a good understanding of the business. So there is equal requirement of skilled personnel in both.

D: Quantitative analysis generally has a better buy-in than qualitative analysis to the point where it can cause over-reliance on the results. Hence this option is not correct.

124) Correct Answer: C

The first step after receiving any change request in a project must be first analyzed for its impact. Changes may be requested by any stakeholder involved with the project. Although, they may be initiated verbally, they should always be recorded in written form and entered into the change management and/or configuration management.

Incorrect Answers:

A, B, D: All these are the required steps depending on the change request. Any change request must be followed by the impact analysis of the change.

125) Correct Answer: AD

The board of directors and senior management has the responsibility to set up the risk governance process, establish and maintain a common risk view, make risk-aware business decisions, and set the enterprise's risk culture.

Incorrect Answers:

B: CFO is the most senior official of the enterprise who is accountable for financial planning, record keeping, investor relations and financial risks. CFO is not responsible for setting up the risk governance process, establishing and maintaining a common risk view, making risk-aware business decisions, and setting the enterprise's risk culture.

C: Human resource is the most senior official of an enterprise who is accountable for planning and policies with respect to all human resources in that enterprise.

HR is not responsible for risk related activities.

126) Correct Answer: D

Mitigation is the strategy that provides for the definition and implementation of controls to address the risk described. Here in this scenario, you are trying to reduce the risk of operation failure by guiding administrator to take daily backup, hence it is risk mitigation.

Risk mitigation attempts to reduce the probability of a risk event and its impacts to an acceptable level. Risk mitigation can utilize various forms of control carefully integrated together. The main control types are:

⇒ Managerial(e.g., policies)

- ☞ Technical (e.g., tools such as firewalls and intrusion detection systems)
- ☞ Operational (e.g., procedures, separation of duties)
- ☞ Preparedness activities

Incorrect Answers:

A: The scenario does not describe risk avoidance. Avoidance is a strategy that provides for not implementing certain activities or processes that would incur risk.

B: The scenario does not describe the sharing of risk. Transference is the strategy that provides for sharing risk with partners or taking insurance coverage.

C: The scenario does not describe risk acceptance; Acceptance is a strategy that provides for formal acknowledgment of the existence of a risk and the monitoring of that risk.

127) Correct Answer: D

Strategic risks are those risks which have potential outcome of not fulfilling on strategic objectives of the organization as planned. Since the strategic objective will shape and impact the entire organization, the risk of not meeting that objective can impose a great threat on the organization.

Strategic risks can be broken down into external and internal risks:

☞ External risks are those circumstances from outside the enterprise which will have a potentially damaging or helpful impact on the enterprise. These risks include sudden change of economy, industry, or regulatory conditions. Some of the external risks are predictable while others are not. For instance, a recession may be predictable and the enterprise may be able to hedge against the dangers economically; but the total market failure may not as predictable and can be much more devastating.

☞ Internal risks usually focus on the image or reputation of the enterprise.

some of the risks that are involved in this are public communication, trust, and strategic agreement from stakeholders and customers.

128) Correct Answer: ABD

The result of risk analysis process is being communicated to relevant stakeholders. The steps that are involved in communication are:

- ☞ The results should be reported in terms and formats that are useful to support business decisions.
- ☞ Coordinate additional risk analysis activity as required by decision makers, like report rejection and scope adjustment
- ☞ Communicate the risk-return context clearly, which include probabilities of loss and/or gain, ranges, and confidence levels (if possible) that enable management to balance risk-return.
- ☞ Identify the negative impacts of events that drive response decisions as well as positive impacts of events that represent opportunities which should channel back into the strategy and objective setting process.
- ☞ Provide decision makers with an understanding of worst-case and most probable scenarios, due diligence exposures and significant reputation, legal or regulatory considerations.

Incorrect Answers:

C: Communicate the negative impacts of events that drive response decisions as well as positive impacts of events that represent opportunities which should channel back into the strategy and objective setting process, for effective communication. Only negative impacts are not considered alone.

129) Correct Answer: A

As new technologies, products and services are introduced, compliance requirements become more complex and stricter; business processes and

related information flows change over time. These changes can often affect the efficiency and effectiveness of controls. Formerly effective controls become inefficient, redundant or obsolete and have to be removed or replaced.

Therefore, the monitoring process has to receive timely feedback from risk assessments and through key risk indicators (KRIs) to ensure an effective control life cycle.

Incorrect Answers:

B: Most of the time, the addition of controls results in degradation of the efficiency and profitability of a process without adding an equitable level of corresponding risk mitigation, hence better controls are adopted in place of adding more controls.

C: A BIA is a discovery process meant to uncover the inner workings of any process. It helps to identify about actual procedures, shortcuts, workarounds and the types of failure that may occur. It involves determining the purpose of the process, who performs the process and its output. It also involves determining the value of the process output to the enterprise.

D: Efficiency and effectiveness of controls are not affected by the changes in technology or product, so some measure should be taken.

130) Correct Answer: CDE

A threat is any event which have the potential to cause a loss. In other word, it is any activity that represents a possible danger. The loss or danger is directly related to one of the following:

☞ Loss of confidentiality- Someone sees a password or a company's secret formula; this is referred to as loss of confidentiality. Loss of integrity- An e-mail message is modified in transit, a virus infects a file, or someone makes unauthorized changes to a Web site is referred to as loss of integrity.

☞ Loss of availability- An e-mail server is down and no one has e-mail

access, or a file server is down so data files aren't available comes under loss of availability.

Threat identification is the process of creating a list of threats. This list attempts to identify all the possible threats to an organization. The list can be extensive.

Threats are often sub-categorized as under:

☞ External or internal- External threats are outside the boundary of the organization. They can also be thought of as risks that are outside the control of the organization. While internal threats are within the boundary of the organization. They could be related to employees or other personnel who have access to company resources. Internal threats can be related to any hardware or software controlled by the business.

☞ Natural or man-made- Natural threats are often related to weather such as hurricanes, tornadoes, and ice storms. Natural disasters like earthquakes and tsunamis are also natural threats. A human or man-made threat is any threat which is caused by a person. Any attempt to harm resources is a man-made threat. Fire could be man-made or natural depending on how the fire is started.

☞ Intentional or accidental- An attempt to compromise confidentiality, integrity, or availability is intentional. While employee mistakes or user errors are accidental threats. A faulty application that corrupts data could also be considered accidental.

131) Correct Answer: C

When the project team needs training to be able to complete the project work it is a cost of conformance to quality.

The cost of conformance to quality defines the cost of training, proper resources, and the costs the project must spend in order to ascertain the expected levels of quality the customer expects from the project. It is the capital used up throughout the project to avoid failures. It consists of two types of costs:

- ☞ Prevention costs: It is measured to build a quality product. It includes costs in training, document processing, equipment, and time to do it right.
- ☞ Appraisal costs: It is measured to assess the quality. It includes testing, destructive testing loss, and inspections.

Incorrect Answers:

A: Benchmarking compares any two items, such as materials, vendors, or resources.

B: Cost-benefit analysis is the study of the benefits in relation to the costs to receive the benefits of a decision, a project, or other investment.

D: Team development describes activities the project manager uses to create a more cohesive and responsive project team.

132) Correct Answer: D

Independence is the freedom from conflict of interest and undue influence. By the mere fact that the external auditors belong to a different entity, their independence level is higher than that of the reviewer inside the entity for which they are performing a review. Independence is directly linked to objectivity.

Incorrect Answers:

A, B, C: These all choices vary subjectively.

133) Correct Answer: C

Decision tree analysis is a risk analysis tool that can help the project manager in determining the best risk response. The tool can be used to measure probability, impact, and risk exposure and how the selected risk response can affect the probability and/or impact of the selected risk event. It helps to form

a balanced image of the risks and opportunities connected with each possible course of action. This makes them mostly useful for choosing between different strategies, projects, or investment opportunities particularly when the resources are limited. A decision tree is a decision support tool that uses a tree-like graph or model of decisions and their possible consequences, including chance event outcomes, resource costs, and utility.

Incorrect Answers:

A: Project network diagrams help the project manager and stakeholders visualize the flow of the project work, but they are not used as a part of risk response planning.

B: The Delphi technique can be used in risk identification, but generally is not used in risk response planning. The Delphi technique uses rounds of anonymous surveys to identify risks.

D: Cause-and-effect diagrams are useful for identifying root causes and risk identification, but they are not the most effective ones for risk response planning.

134) Correct Answer: AD

These three are external risk factors as they lie outside the enterprise's control.

Incorrect Answers:

B: This includes geographic spread and value chain coverage (for example, in a manufacturing environment). That is why it is internal risk factor.

135) Correct Answer: A

Exploit is a method for handling positive project risk.

Incorrect Answers:

B, C, D: These are all responses which is used for negative risks, and not the positive risk.

136) Correct Answer: B

A risk trigger is a warning sign or condition that a risk event is about to happen. Here the warning temperature is 450 degrees Fahrenheit, therefore it is referred as risk trigger.

Incorrect Answers:

A: Risk identification is the process of the identifying the risks. This process identifies the risk events that could affect the project adversely or would act as opportunity.

C: Here risk event is 500-degree temperature, as when machine reaches this temperature it should have to be shut-down for 48 hours, which in turn will laid a great impact on the working of project.

D: Risk response here is shutting off of machine when its temperature reaches 450-degree Fahrenheit, so as to prevent the occurring of risk event.

137) Correct Answer: B

Event nodes represents the possible uncertain outcomes of a risky decision, with at least two nodes to illustrate the positive and negative range of events.

Probabilities are always attached to the branches of event nodes.

Incorrect Answers:

A: Root node is the starting node in the decision tree, and it has no branches.

C: End node represents the outcomes of risk and decisions and probability is not attached to it.

D: It represents the choice available to the decision maker, usually between a risky choice and its non-risky counterpart. As it represents only the choices available to the decision makers, hence probability is not attached to it.

138) Correct Answer: ABC

Security log monitoring, post-implementation reviews of program changes, and Problem management provide indirect information. Security log monitoring provide indirect information about certain controls in the security environment, particularly when used to analyze the source of failed access attempts.

Post-implementation reviews of program changes provide indirect information about the effectiveness of internal controls over the development process.

Problem management provide indirect information about the effectiveness of several different IS processes that may ultimately be determined to be the source of incidents.

Incorrect Answers:

D: Recovery testing is the direct evidence that the redundancy or backup controls work effectively. It doesn't provide any indirect information.

139) Correct Answer: B

Denial-of-service attack (DoS attack) or distributed denial-of-service attack (DDoS attack) is an attempt to make a computer resource unavailable to its intended users. Although the means to carry out, motives for, and targets of a DoS attack may vary, it generally consists of the concerted efforts of person or persons to prevent an Internet site or service from functioning efficiently or at all, temporarily or indefinitely. Perpetrators of DoS attacks typically

target sites or services hosted on high-profile web servers such as banks, credit card payment gateways, and even root name-servers. The term is generally used with regards to computer networks, but is not limited to this field; for example, it is also used in reference to CPU resource management. As the total revenue of the website for the day is \$1 million, and due to denial-of-service attack it is unavailable for half day.

Therefore,

$$\begin{aligned}\text{Revenue loss} &= \$1,000,000/2 - \\ &= \$500,000\end{aligned}$$

Incorrect Answers:

A, C, D: These are wrong answers.

140) Correct Answer: B

Data validation ensures that extracted data are ready for analysis. One objective is to perform data quality tests to ensure data are valid complete and free of errors. This may also involve making data from different sources suitable for comparative analysis.

Incorrect Answers:

A: Analysis of data involves simple set of steps or complex combination of commands and other functionality. Data analysis is designed in such a way to achieve the stated objectives from the project plan. Although this may be applicable to any monitoring activity, it would be beneficial to consider transferability and scalability. This may include robust documentation, use of software development standards and naming conventions.

C: Data gathering is the process of collecting data on risk to be monitored, prepare a detailed plan and define the project's scope. In the case of a

monitoring project, this step should involve process owners, data owners, system custodians and other process stakeholders.

D: In the data access process, management identifies which data are available and how they can be acquired in a format that can be used for analysis. There are two options for data extraction:

- ☞ Extracting data directly from the source systems after system owner approval
- ☞ Receiving data extracts from the system custodian (IT) after system owner approval.

141) Correct Answer: A

A password cracker is an application program that is used to identify an unknown or forgotten password on a computer or network resources. It can also be used to help a human cracker obtain unauthorized access to resources. A password cracker can also check for weak passwords on the network and give notifications to put another password.

Incorrect Answers:

B: Antivirus or anti-virus software is used to prevent, detect, and remove malware. It scans the computer for viruses.

C: Anti-spyware software is a type of program designed to prevent and detect unwanted spyware program installations and to remove those programs if installed.

D: Wireshark is a free and open-source protocol analyzer. It is used for network troubleshooting, analysis, software and communications protocol development, and education.

142) Correct Answer: B

Risk governance is a continuous life cycle that requires regular reporting and

ongoing review, not once a year.

Incorrect Answers:

A, C, D: These are true for risk governance.

143) Correct Answer: B

Secondary risk is a risk that is generated as the result of risk response.

Incorrect Answers:

A: A pure risk is a risk that has only a negative effect on the project. Pure risks are activities that are dangerous to complete and manage such as construction, electrical work, or manufacturing.

C, D: These terms are not applied for the risk that is generated as a result of risk response.

144) Correct Answer: CDE

The outputs of the risk response planning process are:

☞ Risk Register Updates: The risk register is written in detail so that it can be related to the priority ranking and the planned response.

☞ Risk Related Contract Decisions: Risk related contract decisions are the decisions to transmit risk, such as services, agreements for insurance, and other items as required. It provides a means for sharing risks.

☞ Project Management Plan Updates: Some of the elements of the project management plan updates are:

- Schedule management plan

- Cost management plan

- Quality management plan
- Procurement management plan
- Human resource management plan
- Work breakdown structure
- Schedule baseline
- Cost performance baseline

☞ Project Document Updates: Some of the project documents that can be updated includes:

- Assumption log updates
- Technical documentation updates

Incorrect Answers:

A: Risk priority number is not an output for risk response but instead it is done before applying response. Hence it acts as one of the inputs of risk response and is not the output of it.

B: Residual risk is not an output of risk response. Residual risk is the risk that remains after applying controls. It is not feasible to eliminate all risks from an organization. Instead, measures can be taken to reduce risk to an acceptable level. The risk that is left is residual risk. As,

$\text{Risk} = \text{Threat} \times \text{Vulnerability}$ -

and

$\text{Total risk} = \text{Threat} \times \text{Vulnerability} \times \text{Asset Value}$

Residual risk can be calculated with the following formula:

$\text{Residual Risk} = \text{Total Risk} - \text{Controls}$

Senior management is responsible for any losses due to residual risk. They

decide whether a risk should be avoided, transferred, mitigated or accepted. They also decide what controls to implement. Any loss due to their decisions falls on their sides.

Residual risk assessments are conducted after mitigation to determine the impact of the risk on the enterprise. For risk assessment, the effect and frequency are reassessed and the impact is recalculated.

145) Correct Answer: B

The output of the risk assessment process is identification of appropriate controls for reducing or eliminating risk during the risk mitigation process. To determine the likelihood of a future adverse event, threats to an IT system must be analyzed in conjunction with the potential vulnerabilities and the controls in place for the IT system.

Once risk factors have been identified, existing or new controls are designed and measured for their strength and likelihood of effectiveness. Controls are preventive, detective or corrective; manual or programmed; and formal or ad hoc.

Incorrect Answers:

A: Risk identification acts as input of the risk assessment process.

C: This is an output of risk mitigation process, that is, after applying several risk responses.

D: Residual risk is the latter output after appropriate control.

146) Correct Answer: D

Once the set of risk scenarios is defined, it can be used for risk analysis. In risk analysis, likelihood and impact of the scenarios are assessed. Important components of this assessment are the risk factors.

Incorrect Answers:

A: Risk mitigation is the latter step after analyzing risk.

B: Risk monitoring is the latter step after risk analysis and risk mitigation.

C: Risk analysis comes under risk management; therefore, management is a generalized term, and is not the best answer for this question.

147) Correct Answer: ACD

Risk communication is the process of exchanging information and views about risks among stakeholders, such as groups, individuals, and institutions. Risk communication is mostly concerned with the nature of risk or expressing concerns, views, or reactions to risk managers or institutional bodies for risk management. The key plan to consider and communicate risk is to categorize and impose priorities, and acquire suitable measures to reduce risks. It is important throughout any crisis to put across multifaceted information in a simple and clear manner.

Risk communication helps in switching or allocating the information concerning risk among the decision-maker and the stakeholders.

Risk communication can be explained more clearly with the help of the following definitions:

- ☞ It defines the issue of what a group does, not just what it says.
- ☞ It must take into account the valuable element in user's perceptions of risk.
- ☞ It will be more valuable if it is thought of as conversation, not instruction.

Risk communication is a fundamental and continuing element of the risk analysis exercise, and the involvement of the stakeholder group is from the beginning. It makes the stakeholders conscious of the process at each phase of the risk assessment. It helps to guarantee that the restrictions, outcomes, consequence, logic, and risk assessment are undoubtedly understood by all the stakeholders.

Incorrect Answers:

B: It helps in allocating the information concerning risk not only among the decision-makers but also stakeholders.

148) Correct Answer: D

Risk is an uncertain event or condition that, if it occurs, has an effect on at least one project objective.

Project risk is concerned with the expected value of one or more results of one or more future events in a project. It is an uncertain condition that, if it occurs, has an effect on at least one project objective. Objectives can be scope, schedule, cost, and quality. Project risk is always in the future.

Incorrect Answers:

A: Risk is not unknown, it is uncertain; in addition, the event can affect at least one project objective - not just the project scope.

B: This statement is almost true, but the event does not have to happen within project execution.

C: Risks can affect time, costs, or scope, rather affecting only cost.

149) Correct Answer: D

To ensure greater buy-in and ownership, risk indicators should be selected with the involvement of relevant stakeholders. Risk indicators should be identified for all stakeholders and should not focus solely on the more operational or strategic side of risk.

Incorrect Answers:

A: Role of lag indicators is to ensure that risk after events have occurred is being indicated.

B: Lead indicators indicate which capabilities are in place to prevent events from occurring. They do not play any role in ensuring greater buy-in and ownership.

C: Root cause is considered while selecting risk indicator but it does not ensure greater buy-in or ownership.

150) Correct Answer: B

Website defacing is an attack on a website by unauthorized party that changes the visual appearance of the site or a webpage. These are typically the work of system crackers, who break into a web server and replace the hosted website with one of their own.

Incorrect Answers:

A: Ping Flooding is the extreme of sending thousands or millions of pings per second. Ping Flooding attack can make system slow or even shut down an entire site.

C: A denial-of-service attack (DoS attack) is an attempt to make a computer or network resource unavailable to its intended users. One common method of attack involves saturating the target machine with external communications requests, such that it cannot respond to legitimate traffic, or responds so slowly as to be rendered effectively unavailable.

D: The FTP bounce attack is attack which slips past application-based firewalls. In this hacker uploads a file to the FTP server and then requests this file be sent to an internal server. This file may contain malicious software or a simple script that occupies the internal server and uses up all the memory and CPU resources.

Note:.....

.....

Good Luck